



File No.: EXP202213437

RESOLUTION OF SANCTIONING PROCEDURE

From the procedure conducted by the Spanish Agency for Data Protection and based on the following

BACKGROUND.....	4
FIRST:.....	4
SECOND:.....	6
THIRD:.....	6
FOURTH:.....	6
FIFTH:.....	20
SIXTH:.....	20
SEVENTH:.....	20
EIGHTH:.....	36
NINTH:.....	36
TENTH:.....	37
PROVEN FACTS.....	58
FIRST:.....	58
SECOND:.....	58
THIRD:.....	60
FOURTH:.....	60
FIFTH:.....	61
SIXTH:.....	61
SEVENTH:.....	61
EIGHTH:.....	61
NINTH:.....	61
TENTH:.....	62
ELEVENTH:.....	62
TWELFTH:.....	63
THIRTEENTH:.....	64
C/ Jorge Juan, 6	
www.aepd.es	
28001 – Madrid	
sedeagpd.gob.es	
2/89	
FOURTEENTH:	64
FIFTEENTH:	65
SIXTEENTH:	65
SEVENTEENTH:	66
LEGAL GROUNDS	67
I Jurisdiction	67
II Preliminary Issues	67
III Response to the Allegations of the Initiating Agreement	68
IV Response to the Allegations to the Resolution Proposal	71
V Article 5.1.f) of the GDPR	83
VI Qualification of the Violation of Article 5.1.f) of the GDPR	84
VII Sanction for Violation of Article 5.1.f) of the GDPR	85
VIII Article 32 of the GDPR	88
IX Article 25 of the GDPR	94
X Qualification of the Violation of Article 25 of the GDPR	97
XI Sanction of Article 25 of the GDPR	97

XII Liability	100
XIII Measures	101
RESOLVES:	101

BACKGROUND

FIRST:

On October 19, 2022, A.A.A., representing B.B.B. and C.C.C. (hereinafter, claimant 1 and claimant 2 respectively) filed a complaint with the Spanish Data Protection Agency.

The complaint is directed against CAIXABANK, S.A. with NIF A08663619 (hereinafter, the respondent).

The grounds for the complaint are as follows:

The representative of the claimants states that her clients are customers of the respondent. Claimant 1 has three accounts open with this entity, appearing as the holder on two of them and her mother as authorized. In the third account (ending in ***REFERENCE.1, hereinafter shared account), claimant 1 and claimant 2 are listed as co-holders, with no other person appearing either as holder or as authorized.

She states that when claimant 1 attempts to carry out any operations with her accounts through online banking, the signature of the authorized person is required not only if the operation is performed from one of the two accounts where she is authorized but also if they wish to carry out an operation in the account of which claimant 2 is a co-holder (the one ending in ***REFERENCE.1) and in which claimant 1's mother is not listed as authorized.

Furthermore, when the authorized person for two of the accounts of which claimant 1 is a holder accesses the personal area through "CaixaBankNow," she can view not only the information related to the accounts and the products linked to them where she is listed as authorized, but she can also view information related to the cards linked to the third account (ending in ***REFERENCE.1) for which she has no capacity, either as a holder or as an authorized person.

As a result of what occurred, numerous complaints were filed with the respondent, as well as a complaint with the Bank of Spain, without the issue being resolved.

In the complaint, it is stated that "The initial response given to claimant 1 is that at some point in the year 2009 she signed a 'future contract,' without specifying which one or providing the supposed signed document by B.B.B. and D.D.D., by which the latter would have access to all that information."

Relevant documentation provided by the claimant:

- Thread of email messages maintained by claimant 1 with her CaixaBank manager (from January 14 to February 17, 2021).
- Copy of the complaint letter from claimant 1 which bears the stamp of receipt from the respondent dated February 17, 2021.
- Response dated March 23, 2021, confirming receipt of the complaint.
- Exchange of emails maintained by claimant 1 with the Data Protection Department of the respondent (on February 19 and 21, 2021).
- Documentation related to the procedure followed before the Bank of Spain (complaint filed on ***DATE.1), among which the following stands out:

o Proposal for an amicable solution from CaixaBank (***DATE.2) offering financial compensation and the signing of a withdrawal agreement of the complaint, adding the respondent the following:

☐ "It seems that there was a technical incident with the users of claimant 1 and her mother that should be resolved by providing new access keys to claimant 1 and her mother."

o Letter from claimant 1 addressed to the Bank of Spain communicating that the incident has not been resolved, rejecting the proposed solution.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

4/89

amicable and requests the continuation of the processing of the claim presented.

or

Report from the Bank of Spain (dated ***DATE.3) indicating that the actions of the claimed party may have violated transparency regulations, in addition to not having diligently corrected the incident or error. Among the arguments in this report (section 1, general criteria) is the following:

□

Authorized persons are individuals who, with the express consent of the account holders, can generally dispose of the existing balance in the account. They are not authorized to modify the terms of the contract, nor to cancel the account, nor to make withdrawals from the account after the death of the holder. The status of authorized person is obtained through express authorization from the account holder(s) and usually in writing, being common banking practice to collect at that moment both the signatures of the holders and those of the authorized persons.

In section 2 (study of the particular circumstances that apply here) it is indicated as follows:

The entity, in its two written submissions, acknowledges the incident or error and communicates that it has been resolved. As documentation attached to its submissions, it only provides the email sent to the claimant on July 8, 2021, in which its lawyers stated that, as discussed over the phone, they wished to convey to the claimant CaixaBank's willingness to find an amicable solution to the situation and that there had been a technical incident with the users, the office would initiate the procedures to verify that the keys were issued correctly, before calling them to deliver them, and to compensate the claimant for the delay in resolving the case, they would offer a compensation of €150.

- Copy of the claim submitted by claimant 2 against the claimed party (on October 5, 2021)
- Copy of the response from the claimed party to this submission made by claimant 2 (dated October 27, 2021) indicating that the matter is being resolved before the Bank of Spain.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

5/89

SECOND:

In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter LOPDGDD), on February 21, 2022, the aforementioned claim was forwarded to the claimed party, so that it could proceed with its analysis and inform this Agency within one month of the actions taken to comply with the requirements set forth in data protection regulations.

On 10/02/2023, the claimed party submitted a response to the transfer indicating the following:

"Due to the claim forwarded by this Agency, CaixaBank has reviewed the operations and authorizations enabled in the Online Banking service (CaixaBank NOW) of the claimant, and from this review, it has not been possible to verify the allegations in the claim regarding the visibility of their products by other authorized users in their Online Banking and the need for signatures from these authorized persons when the claimant performs operations on the products they intend to operate. For all these reasons, we have requested the claimant to maintain a personal interview with the specialized technical team in CaixaBank NOW, as well as the usual manager of the client, in order to restore and reconfigure the authorizations of their products according to their indications and specifications. Attached is the communication sent to the email address provided by the client, to which we await a response by the date of this written response. Annex I."

The communication referred to in Annex I of the response to the transfer is an email sent from: DATA PROTECTION DELEGATE to the email address of claimant 1 on 09/02/2023.

THIRD:

On January 19, 2023, in accordance with Article 65 of the LOPDGDD, the claim submitted by the claimant was admitted for processing.

FOURTH:

The General Sub-Directorate for Data Inspection proceeded to carry out preliminary investigative actions to clarify the facts in question, by virtue of the functions assigned to the control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data

Protection Regulation, hereinafter GDPR), and in accordance with the provisions of Title VII, Chapter I, Section two, of the LOPDGDD, being aware of the following points:

Claimant 1 informed the claimed party of the facts contained in the claim submitted to the AEPD:

Thus, she provides various emails dated 11/01/2021 and 14/01/2021 between her and atencion.clientes@contactcenter.caixabank.com in which screenshots of the digital piggy bank are included with the following messages: "You have prepared..."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

6/89

"the operation has been correctly executed and sent for signing to the required signatories," with the claimant 1 listed as signatory 1 and her mother as signatory 2, and "Your request for multiple signatures has been executed correctly, but we have been unable to notify all the signatories. The operation will conclude when all necessary signatories have confirmed it," although it is not clear which account is associated with the digital piggy bank.

She also provides several emails exchanged with her personal manager at CAIXABANK, between 10/02/2021 and 17/02/2021, in which claimant 1 reiterates that her mother has access to view her accounts, both those solely owned by her and the one co-owned with claimant 2, being able to see those accounts as well as the associated cards, the mortgage, the PIAS, etc.

She also submits a complaint regarding the transfer of data to third parties addressed to the Customer Defender or Customer Service, dated 16/02/2021, in which she states the following facts:

1º.- That to carry out operations such as "creation of piggy banks" on any of her accounts, whether exclusively owned or shared with claimant 2, claimant 1 requires both her signature and her mother's.

2º.- Transfer of data by La Caixa to a third party without authorization:

- All cards linked to the account ending in ***REFERENCIA.1 (there are 3 cards) are viewed by a person who is neither the account holder nor authorized for that account.
- Everything linked to accounts ***REFERENCIA.2 and ***REFERENCIA.3, mortgages, life insurance, home insurance, PIAS cards... is viewed by the authorized person on those accounts.
- These facts have already been repeatedly communicated to her branch, without these incidents being corrected as of the date of this document.

She requests that appropriate instructions be issued to:

- That La Caixa rectify the signature error.
- Send the future contract.
- Provide solutions for the significant problem of data transfer of both claimant 1 and claimant 2 to a person without prior authorization.
- Annul the alleged future contract.

She also provides the response dated 23/03/2021 from the Customer Service of CaixaBank, in which they state that the complaint has been received and that they will try to resolve it as soon as possible.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

7/89

She also provides communications with the email address

delegated.proteccion.datos@caixabank.com between 19/02/2021 and 21/02/2021, informing them of the facts subject to the complaint.

Additionally, she provides communications with caixabank@fyrlegal.com. In these communications, acting as lawyers for CAIXABANK, a settlement proposal is sent to resolve the complaint made by claimant 1, indicating that the incidents of the complaint have been resolved and that in exchange for her renouncing to file any complaint, they will compensate her with €150. Claimant 1, in these communications, expresses her disagreement with the resolution of the incidents of the complaint and

at no time accepts the proposed compensation.

The responding party was aware of the claimed facts since they were brought to their attention through various email threads.

In the Report from the Conduct Department of Entities of the Bank of Spain regarding the complaint filed by B.B.B. against the entity CAIXABANK, S.A., dated December 23, after focusing on the subject of the complaint presented to the Bank of Spain regarding the fact that "the claimant (1) states that she has three accounts and in two of them her mother is authorized, and in another (with number ending in ***REFERENCIA.1) she shares ownership with another person, C.C.C. She expresses her disagreement because, as she says, her mother has access to information about the third account and associated cards as well as to the products associated with the first two accounts (insurance, mortgage, loans, etc.), for which she did not grant authorization. She accuses the entity of thus violating her rights and those of the other co-holder. She claims that she communicated this fact to the entity in January 2021 and subsequently filed a complaint, but the entity did not provide her with a response."

It also includes the allegations of the responding party stating that "they again request the file of the case due to compliance and state that they have made the necessary regularizations of their control marks (substituting the 'authorized' mark for the 'authorized' mark), source of the administrative error suffered, thereby automatically updating and correcting the visualization powers of the claimant's mother. They mention that at that time the claimant's mother could make inquiries, through the CaixaBankNow digital banking service, only about the products for which she is authorized: the current accounts number ...***REFERENCIA.2 and ...***REFERENCIA.3:"

And the allegations of the claimant party regarding the previous statements of the responding party in the following terms: "She states that, although the documentation provided by CAIXABANK indicates that everything is resolved, as of that date (02/09/2021) it is false and provides demonstrative videos." Next, it proceeds to express the "Opinion of the Department" where, after establishing the following "General Criteria": "Authorized persons are individuals who, with the express consent of the holders, can generally dispose of the existing balance in the account (...)" "(...) The condition of authorized person is obtained by express authorization from the holder or holders of the account and usually in writing,

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
8/89

It is a banking practice to collect both the signatures of the account holders and the authorized persons at that moment.

And that "This Department has reiterated that, in general, the powers of action of the authorized person will depend on the authorization document signed;"

Pointing out in the "Study of the particular circumstances that are present here" that:

"In this case, the claimant (1) is the holder of three accounts and states that she has only authorized her mother on two of them. She provides videos showing that her mother, with her internet user account, has access to information about all her products (of the claimant), including one account and products for which she was not authorized. The entity, in its two written responses, acknowledges the incident or error and communicates that it has been resolved." And that "The claimant (1), however, in her various writings, the last one dated September 2, 2021, indicates that the problem remained unresolved and provides demonstrative videos."

Concluding in its report that "This Department considers that the actions of the entity may have violated the regulations on transparency and protection of banking clients, (...) to the extent that, having made the account holder's disagreement with the fact that the authorized person accessed information about her products evident, it did not respond in a timely manner to the complaint, nor does it demonstrate having diligently corrected the incident or error."

On May 24, 2023, a request for information was sent to the responding party in order to clarify the facts contained in the complaint filed by the claimant in the following terms:

- 1.- The provision of technical reports or recommendations prepared by the Data Protection Officer or by the security officer, regardless of their format, regarding the treatments for which information is requested, as well as the subsequent actions taken or their absence, derived from the aforementioned technical reports or recommendations.
- 2.- The decision made regarding this complaint.
- 3.- Report on the causes that have led to the incident that originated the complaint.
- 4.- Report on the measures taken to prevent similar incidents from occurring, implementation dates, and controls carried out to verify their effectiveness.
- 5.- Any other information deemed relevant. Additionally, information must be provided regarding:
- 6.- The data that CAIXABANK holds regarding the holders and authorized persons in the three accounts referred to in the complaint, and regarding the products linked to them. The contracts under which this data is held must be provided.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

9/89

- 7.- If B.B.B. and her mother signed a "future contract" in 2009, a copy of that contract must be provided.
 - 8.- What is the procedure followed by CAIXABANK to allow its clients to operate through online banking in the case that there are holders and authorized persons on the same account? Specifically, the movements of the three accounts in which the signature of D.D.D. has been required must be provided, from January 2021 to the date of this request.
 - 9.- In relation to the electronic banking application of Caixabank (Caixabank Now), what protocols does CAIXABANK have established for access by holders and authorized persons to the accounts through said application, to the accounts, to the services associated with them, or to both? Specifically, what accesses or authorizations has D.D.D. had in relation to the three accounts subject to the complaint, from January 2021 to the date of this request through said application?
 - 10.- What security measures have been established in relation to data protection in the electronic banking application of Caixabank (Caixabank Now), to ensure that only those who are truly authorized can access it?
 - 11.- What security measures does CAIXABANK have in place to prevent possible technical incidents to avoid occurrences like those mentioned in this complaint?
 - 12.- What has been the participation of the Data Protection Officer regarding the measures adopted? Technical reports or recommendations that may have been made in this regard must be provided.
- On June 16, 2023, the responding party submitted a written response to the request in which it stated, among other aspects, that in relation to the aforementioned writing, they were sending the following information/documentation:

In relation to point 1 of the request, the responding party states that "The Data Protection Officer has coordinated, along with the security officers of the Entity, the analysis of the complaint from B.B.B. and, due to the impossibility of reproducing the incidents described by the Claimant (1), proposed to hold a meeting with her in which, accompanied by specialists in the Entity's online banking applications, attempts would be made to reproduce the alleged errors and, if it was determined that there was no technical incident but rather an incorrect configuration of visualizations by the user, assistance would be provided to configure the accesses according to her requirements. This suggestion was adopted and communicated to the Claimant (1) and to the AEPD.

In execution of the recommendation of the DPO, CaixaBank attempted to schedule an in-person appointment with the Claimant (1) at her managing office in order to configure, according to her preferences, the operational and visualization powers of her products for the authorized users designated in her Online Banking contract.

C/ Jorge Juan, 6
www.aepd.es

The Claimant (1) has declined on several occasions through their manager to maintain this in-person appointment for the review of their viewing preferences and operational capabilities of their authorized persons, which has made it impossible for CaixaBank to know whether the current configuration of the Claimant's (1) Online Banking contract is suitable or not for their preferences.

At the same time, CaixaBank has reviewed the different viewing options and operational powers regarding the Claimant's (1) Online Banking contract (CaixaBankNOW) since D.D.D. was registered in it, not detecting any incidents and confirming the following aspects: (screenshots of each of the authorizations are attached)

i. On February 3, 2021, the Claimant (1), B.B.B., contracted Online Banking (CaixaBankNOW contract). In the registration process of this Online Banking contract, the Claimant (1) included their mother, D.D.D., as an authorized person in this contract, with a level of "All permitted," which, as stated in the contract signed by the Claimant (1), grants this authorized person the authority to operate on the products for which viewing is permitted, specifically the accounts ending in ***REFERENCE.2 and ***REFERENCE.3 and the products linked to these accounts. The signed CaixaBank NOW contract by the Claimant is attached as Annex I.

ii. On August 4, 2021, at the request of the Claimant (1), a modification was made regarding the options described in the previous point concerning the viewing and management established at the registration for D.D.D., changing the viewing level from "All permitted" to "Customized," and expanding the visibility over the Claimant's accounts. Specifically, visibility was allowed for the accounts ending in: ***REFERENCE.2, ***REFERENCE.3, ***REFERENCE.1.

iii. On August 10, 2021, from the managing office, at the request of the Claimant (1), other products were excluded from the visibility of the authorized person, as can be seen in the attached image; the visibility of the cards associated with the Online Banking contract could not be viewed by the authorized person on this date.

iv. On August 11, 2021, another modification was made by the Claimant (1) in their managing office regarding the viewing options of the authorized person in their Online Banking contract, which is the status as of the date of this claim. According to this modification by the Claimant, the authorized person, D.D.D., was again authorized to view the card contracts and all of the Claimant's accounts. For all these reasons, as of the date of receipt of this claim, we understand that the operations and viewing of the authorized person of the Claimant (1) in their Online Banking contract are correct and correspond to the examples provided by the Claimant in their claims, as the viewing of the products permitted by the Claimant in their CaixaBankNOW contract is detailed in the explanations attached in point 3 below."

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
11/89

Regarding point 2 of the request. The responding party states that "as reported to this Agency and reiterated in this document, upon reviewing the viewing permissions of those authorized in the CaixaBankNOW contract of the Claimant (1), no incidents were found, which is why an attempt was made to maintain a personal interview with the Claimant to convey her preferences regarding the viewing and management options authorized in her CaixaBankNOW contract. As of the date of this document, the Claimant has declined this proposal for a personal interview. No further actions have been taken due to the lack of further instructions from the Claimant."

Regarding point 3 of the request, the responding party states that "no incidents have been detected by CaixaBank in the online banking operations of the Claimant (1) and the complaints regarding the functionalities of the Claimant's online banking (1) are due to her own choices in the configuration of the views. Analyzing in detail the video provided by B.B.B. as supposed evidence of an incident, and in what is alleged in her complaint where she indicates that the authorized person in her Online Banking

can see card transactions that are not associated with B.B.B. but with C.C.C., we can confirm that the operation reproduced in the video is correct, and this is for the following reasons:

- The video, dated September 1, 2021, shows how D.D.D. (authorized) can view the card contract No. (...) ***REFERENCE.5, owned by B.B.B. Correct viewing as the authorized person was permitted to consult these products on that date.
- In this card contract, owned by the Claimant (1), there are several linked cards (beneficiaries), three of which are in the name of C.C.C. (a detail of the card contract and the video is attached). This point is particularly relevant to clarify some of the complaints of the Claimant (1): the contracts for these cards are not owned by C.C.C., they are owned by the Claimant (1), B.B.B., who has requested that cards be issued in favor of a third party (C.C.C.). Therefore, the Claimant (1) as the owner of the contract has access to all transactions, and consequently, so do the persons authorized by the owner herself, in this case, D.D.D. does not access a contract of C.C.C., she accesses a contract of the Claimant (1), B.B.B., who has requested cards in the name of a beneficiary, C.C.C.

As the video progresses, it is observed that the authorized person, according to the viewing options established by the Claimant, can access this card contract No. (...) ***REFERENCE.5, and the transactions of the cards associated with it, as they are owned by B.B.B. (a detail of the transactions of the card contract and the video is attached).

For all the reasons stated in this point, and throughout this document, it is concluded that the operation viewed by the authorized person is correct, as the transactions of the cards viewed on September 1, 2021 (the date of the provided video) are those associated with all the beneficiary cards of card contract No. (...) ***REFERENCE.5 owned by the Claimant (1), B.B.B., and configured by her the viewing option for cards since August 11, 2021. Therefore, from CaixaBank, upon receiving the complaint sent by the Agency, verified the

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
12/89

correct functioning of the online banking contract of the Claimant and not finding any incident, it has been insisted to the Claimant, and we have informed this Agency, to maintain a personal interview between her and technicians of the Entity, to make the modifications that she deems appropriate so that her authorized users can view the products according to their preferences.”

In relation to point 4 of the request, the responding party states that “no additional measures have been adopted beyond those already implemented for the development and security of its applications, as no incident has been detected in the present claim.”

Regarding point 6 of the claim, the responding party indicates that “In the claim forwarded by this Agency, reference is made to three accounts owned by the Claimant, specifically:

i. Account ending in ***REFERENCE.1

This account lists B.B.B. and C.C.C. as account holders.

The following products are linked to this account:

Card contract No. (...) ***REFERENCE.5: Ownership of B.B.B. Associated with this card contract, C.C.C. is listed as the beneficiary and holder of three cards.

CaixaBank NOW contract (...) ***REFERENCE.7: Ownership of C.C.C.

ii. Account ending in ***REFERENCE.2 This account lists B.B.B. as the holder and D.D.D. and E.E.E. as recognized signatories.

This account is linked to the following product: CaixaBank NOW contract (...) ***REFERENCE.6.

Ownership of B.B.B. and where D.D.D. is listed as authorized. This contract signed by the holder is attached to this document as Annex I.

iii. Account ending in ***REFERENCE.3 This account lists B.B.B. as the holder and D.D.D. as the recognized signatory.

“The following products are linked to this account”: 5 card contracts with various associated cards, all of which are owned by responding party 1; 1 mortgage loan, where responding party 1 is listed as the holder, and two other guarantors; 3 insurance contracts owned by claiming party 1; and 1 pension

plan, also owned by claiming party 1.

Regarding point 7 of the request, the responding party states that: "The 'futures contract' referred to could not be identified, as there is no contract with that designation in the entity's product portfolio, and no contract belonging to the Claimant and her mother has been located in the cited year that could correspond to this designation."

In relation to point 8 of the information request, the responding party states that its clients "can allow access to authorized third parties to their digital banking; consequently, when a person is listed as authorized by the account holder (the case at hand), this person, in their capacity as an authorized third party (in this case, the mother of the Claimant (1)), has the corresponding access to the information of the authorizing account holder (the Claimant (1)). This operation of the authorized users in the Online Banking contract is described in the contract signed by the clients, which, for the specific case at hand, was signed by the Claimant (1) and is attached to this document as Annex I.

In this contract, it is expressly stated:

"1.2. Additionally, you may designate other persons to use your CaixaBankNOW:

- Authorized users:
- Customized users: according to the following levels:
 - Basic
 - Consultation
 - Consultation and
 - All permitted.
 - Detailed."

At the same time, all clients have available, at all times in their online banking, the consultation of the details of their CaixaBankNOW contract.

Within personal settings, they have the option enabled "Consult my CaixaBankNOW digital banking contract," where all the contract details, authorized users, and access levels appear. We attach a sample screen.

And not only is the consultation operation available to all clients holding CaixaBankNOW contracts, they can also make modifications to the visualization of their authorized users' products according to their preferences."

And that, "Upon reviewing the operations carried out by the Claimant (1) in her online banking, as well as by her authorized user, D.D.D., no operations have been found where the signature of the authorized user was required for the execution of operations initiated by the Claimant."

Regarding the electronic banking application of CaixaBank (CaixaBankNOW) referred to in point 9, the responding party states that:

"The access protocols for holders and authorized users to accounts and services by holders and authorized users are those described in section 8 of this document, which are defined by compliance with the requirements established by the PSD2 (Payment Services Directive).

(...)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

14/89

Specifically, what accesses or authorizations has D.D.D. had in relation to the three accounts subject to the claim from January 2021 until the date of this request through the application?

Attached is a detailed account of the accesses and authorizations of D.D.D. to the three accounts subject to the claim as Annex IV.

The last access to the Claimant's products through Online Banking recorded in our systems by D.D.D. is from September 2021.

Regarding point 10 of the request, the appealing party states that "it has implemented internal regulations that are mandatory, established under the Information Security Policy of the CaixaBank Group, which outline the security requirements for all types of banking conducted through electronic means, ensuring the application of minimum security requirements in this area.

Concerning the security measures related to CaixaBank customers' access to their online banking, in addition to the additional measures implemented by the entity, the applicable current regulations for CaixaBank in this area, as a payment institution, known as PSD2 (Payment Services Directive), specifically:

- Delegated Regulation (EU) 2018/389 of the Commission, of November 27, which complements Directive (EU) 2015/2370 of the European Parliament and of the Council regarding the technical regulatory standards for strong authentication,

- Royal Decree-Law 19/2018, of November 23, on payment services and other urgent financial measures, obliges CaixaBank to establish security controls regarding its customers' access to their online account, and requires, among other aspects, that when accessing, they do so with strong authentication.

(...).

Specifically, for the development and operation of electronic banking (CaixaBankNOW), the following security measures, both generic and specific, are detailed that ensure, at all times, both secure access by the holders of electronic banking contracts and the certainty or guarantee of access only by authorized persons to the information.

(...)

And a series of "SPECIFIC SECURITY REQUIREMENTS (...).

Regarding point 11 of the request, it states in its writing that "no additional security measures will be established beyond those already implemented for the development and operation of its Online Banking, as no technical incident has been detected that necessitates the implementation of new measures."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

15/89

Regarding point 12 of the request, it states that:

"The Data Protection Officer of CaixaBank participates and intervenes in the initial design phase of all personal data processing carried out by the entity as an advisor and supervisor of compliance with privacy regulations, participating adequately and in a timely manner in all data protection matters. As required by data protection regulations, CaixaBank has equipped itself with both the necessary methodology to carry out impact assessments of all processing that the entity will undertake, as well as a specific Committee, specifically the Risk Management and Impact Assessments Committee: a delegated committee of the Privacy Committee, responsible for the analysis and approval of any New Processing, where the participation of the DPO is present at all times.

This document includes the analyses carried out by both the Data Protection Officer and the Information Security area of CaixaBank regarding the security measures implemented for access and management of electronic banking by customers that guarantee the protection of personal data of customers and users of electronic service channels."

From the above, the Inspection Services highlight the following aspects:

The terms in which the underlying issue of the claim is presented consist of determining whether the procedure of the responding party, which outlines the operations for accessing financial product information by third parties other than the holders, allowed the mother of Claimant 1 access to the solely owned accounts of Claimant 1 and to the joint account of Claimant 1 and Claimant 2, as well as to the products associated with such accounts and their transactions; and whether the signature of the mother of Claimant 1 was also required for certain operations in the claimants' accounts.

From the response to the request and the documentation included therein, the following points are observed:

The responding party states that it has a procedure that outlines the operations for accessing financial product information by third parties other than the holders, where it describes how the authorization

system works, the types of permissions available, and their scope, stating that:

"This operation of the authorized parties in the Online Banking contract is described in the contract signed by the clients (...)".

In the general conditions of the contract signed by Claimant 1, it is expressly stated:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

16/89

"1.2. Additionally, you may appoint other individuals to use your CaixaBankNOW:

➤ Authorized users: you authorize these individuals to access your CaixaBankNOW at the Basic Access, Consultation, or Consultation and Preparation levels (see the next point), unless you inform us otherwise. This authorization becomes void when the time period for which you have authorized it expires, or if you notify us that you no longer wish for the individual to be authorized.

➤ Customized users: you can decide the level of access you grant to these individuals, according to the following levels:

- Basic: allows the user to submit documents to carry out various operations, such as direct debits, transfers, etc., which require the signature of the account holder or a user with full powers. The purpose is for the user to prepare the operations for you, as the holder, to consent to later.
- Consultation: allows the user to consult the contracted services, as well as their specific operations.
- Consultation and preparation: is the sum of the two previous levels.
- All permitted: the user can access all services offered by CaixaBankNOW.
- Detailed: the user can have different levels of access, depending on the type of service: current account, investment fund, insurance, etc."

In turn, all clients have available, at all times in their online banking, the consultation of the details of their CaixaBankNOW contract. Within personal settings, they have the option enabled "Consult my CaixaBankNOW digital banking contract," where all contract details, authorized users, and access levels appear.

And not only is the consultation operation available to all clients who hold CaixaBankNOW contracts, but they can also make modifications to the visibility of the products of their authorized users according to their preferences."

The claiming party provides a copy of CaixaBankNOW contract no. (...) ***REFERENCE.6 of claimant 1, in which they appear as the first and only holder, dated 03/02/2021, associated with the account ending in ***REFERENCE.2 in the section of this contract "AUTHORIZED USERS" Persons who can access your CaixaBankNOW includes the mother of claimant 1, who is assigned the user number ending in ***REFERENCE.8 and Operational Level.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

17/89

It also provides a copy of CaixaBankNOW contract no. (...) ***REFERENCE.7 of claimant 2, in which they appear as the first holder, dated 18/01/2021, associated with the account ending in ***REFERENCE.1, and in which no authorized user is listed.

Application to the specific case of the claimants

Claimant 1 is the exclusive holder of the following products:

i.

Account ending in ***REFERENCE.2 In this account, B.B.B. is listed as the holder and D.D.D. and E.E.E. as recognized signatures...

This account is linked to the following product: CaixaBank NOW Contract (...) ***REFERENCE.6. Ownership of B.B.B. and where D.D.D. is listed as authorized.

i.

Current account ending in ***REFERENCE.3 In this account, B.B.B. is listed as the holder and D.D.D. as the recognized signature.

"To this account, the following products are linked": 5 card contracts with various cards associated with them, all of which are owned by claimant 1; 1 mortgage loan, where claimant 1 is listed as the holder, along with two other guarantors; 3 insurance contracts owned by claimant 1; and 1 pension plan, also owned by claimant 1.

Claimant 1 and claimant 2 are co-holders of the following product:

i.

Account ending in ***REFERENCE.1.

To this account, the following products of claimant 1 are linked:

-

Card contract No. (...) ***REFERENCE.5: Ownership of B.B.B.

According to the claiming party, associated with this card contract is the beneficiary and holder of three cards C.C.C..

Regarding the information provided, it should be noted that while a copy of the card contract No. (...) ***REFERENCE.5, which is owned by claimant 1, is attached, this contract does not list any beneficiary/holder of other cards associated with this contract; however, there is a section "Maintenance of additional card (beneficiary) 48 euros per year per card."

And in the screenshot presented as supporting documentation that claimant 2 is the beneficiary/holder of the three cards requested by claimant 1, the inquiry was made under "Cards of the contract" where four cards appear, one of which lists claimant 1 as the holder and the other three list claimant 2 as the holder, with two of these cards showing in the "Type" field "Apple Pay – Smart Phone." Meanwhile, in the rest of the screenshots referred to...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

18/89

In relation to the other accounts, the inquiry to show the associated cards is by "Related Persons."

-

Contract CaixaBankNOW (...) ***REFERENCE.7: Ownership of C.C.C.

The claimant asserts in their response to the information request that if the mother of the claimant had access to the financial products of claimants 1 and 2, it is because she had the appropriate visibility permissions to view them, being authorized in the CaixaBankNOW contract of claimant 1, who requested the responding party to make the modifications so that on each date her mother could have visibility of the products she accessed.

In this regard, it should be noted that while the responding party provides screenshots of the modifications referenced, indicating that they were made at the request of claimant 1, they do not provide any evidence of the existence of the request from claimant 1, or that she personally made the modifications.

Furthermore, it should be noted that in their supplementary allegations submitted to the Conduct of Entities Department of the Bank of Spain in response to the letter sent by that Department dated ***DATE.4, the responding party, after stating in their sole allegation "That CaixaBank has proceeded to make the necessary regularizations of its control marks (substituting 'apoderada' for 'autorizada'), source of the administrative error suffered, which automatically updates and corrects the visualization powers that the mother of the claimant has over her products, thanks to which it currently shows that through the CaixaBankNow internet digital banking service, the mother of the claimant can only make inquiries about the products for which she is authorized, which are currently the current accounts number (...) ***REFERENCE.2 and (...) ***REFERENCE.3," states that it justifies "the regularizations made in this regard, both concerning the accounts and the limitation of card movements," providing two screenshots, dated ***DATE.4. The first is the same screenshot presented in the response to the information request, where access to the accounts ending in ***REFERENCE.3 and ***REFERENCE.2 is marked with a green checkmark, and the accounts ending in ***REFERENCE.4

and ***REFERENCE.1 are marked with a red cross. This same screenshot also appears after another screenshot in which the modification date is shown as 03/02/2021, with the object of the modification being: the user; the action taken: the registration; the user number: ending in 01; the name of the user: that of the mother of claimant 1; and as a value after the modification: All permitted.

The second is the same screenshot as that included in the response to the information request, where it is indicated that "On August 10, 2021, from the managing office, at the request of the Claimant, other products were excluded from the visibility of the authorized person, as can be seen in the attached image, the visualization of the cards associated with the Online Banking contract cannot be viewed by the authorized person on this date."

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
19/89

In relation to the accesses and authorizations of D.D.D. to the three accounts subject to the claim that the responding party submits as Annex IV, it is worth noting that this Annex IV is an Excel Sheet with three tabs: "Access CaixabankNOW," which lists accesses between 04/02/2021 and 03/08/2021; during this period, the mother of claimant 1 has access to the accounts with two different profiles as user ending in 01, accessing with the proxy profile; and between 10/08/2021 and 29/09/2021 as user ending in 02, accessing with the authorized profile); "Account Consultations CaixabankNOW," which shows that as user 02, she consulted the movements of the three accounts subject to the claim on the aforementioned dates and that on 10/08/2021 as user 02, she made 15 consultations to the account ending in ***REFERENCE.1 between 15:07 and 15:48 hours; and, "Signed Movements," where two movements made as user 01 between March and July 2021 are recorded.

FIFTH:

The entity CAIXABANK, S.A. has a business volume of 964,711 million euros, in accordance with the data indicated on page 11 of the results presentation published by the entity itself in October 2023.

SIXTH:

On January 16, 2024, the Director of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against the responding party, in accordance with the provisions of Articles 63 and 64 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), for the alleged infringement of Article 25 of the GDPR and Article 32 of the GDPR, classified in Article 83.4 of the GDPR and Article 5.1.f) of the GDPR classified in Article 83.5 of the GDPR.

SEVENTH:

Notified of the aforementioned initiation agreement in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), the responding party submitted a written statement of allegations in which, in summary, it presents two claims:

The sanctioning procedure should be archived due to lack of typicity, supporting its assertion on the following:

- The exercise of rights through third parties.
- D.D.D. was authorized by B.B.B. to view the information related to the Shared Account, acting validly as a substitute in the exercise of her right.
- Exercise of informational autonomy.

And as a second allegation, it states that it acted based on a coherent, historical, and consolidated interpretation of the norm in accordance with the civil code.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

The allegations presented by the responding entity were supported by the following assertions:

“The sanctioning procedure should be archived due to lack of typicity.

Access to the shared account by the representative of the co-holder was consented by C.C.C.: the shared account is subject to the regime of solidarity.

The shared account is of a solidary nature, so any of its co-holders is empowered to individually consult the information of the account, being irrelevant whether such right is exercised by the co-holder or by a third party authorized by them.

The shared ownership of a legal situation requires determining the regime to which the exercise of rights by the subjects that are part of that shared ownership must be subject.

The exercise of rights by the holders of a shared legal situation can be organized in two ways: through “solidarity” or by means of “joint ownership.”

Solidarity implies that each of the co-holders can exercise all the rights related to the shared legal situation individually and independently of the others, so that each of the co-holders has “the right to demand...in full the things subject to it” (Article 1,137 of the Civil Code), as if they were a single holder. In contrast, joint ownership (arg. Article 1,139 of the Civil Code) requires the simultaneous concurrence of all holders for the legal act to be validly produced. The rights must be exercised “in common hand” by all co-holders, who cannot exercise the rights individually, as is typical of solidarity. In this sense, the difference between a bank account being solidary or joint is that in the first case, the co-holders may exercise the rights attributed to them by the contract with the banking entity independently and without requiring the concurrence of the other co-holder. In contrast, if the bank account is subject to the regime of joint ownership, the consent of all co-holders will be necessary to exercise any right provided for in the current account contract.

The above is expressly stated in clause 1 of the general conditions of the Current Account Contract, which establishes the following:

“1.3. You can be the sole holder (individual ownership) or share co-ownership with other persons. If you share co-ownership with other persons, you can do so in the modality of ‘solidary’ responsibility or in the modality of ‘joint’ responsibility.

1.4. Solidary responsibility is what we will apply if you do not tell us otherwise; it means that each of the holders can operate on their own and exercise all the rights of the contract, including canceling it, unless a law indicates otherwise.

1.5. Only if you expressly request it, and it is stated in the particular conditions, will the modality of joint responsibility apply.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

the signature and acceptance of all or several holders is necessary to carry out any operation.”

Well, in the case at hand, the parties to the Current Account Contract agreed that each of the holders of the Shared Account could validly exercise their rights in relation to that account independently of the other, without the presence of the other holder. This is established in section four of the specific conditions in the following terms:

4. DECISIONS ON THE CONTRACT

Modality

Joint (if in doubt, refer to clause 1 of the general conditions)

In this regard, each of the co-holders had the “right to request” (Article 1,137 of the Civil Code) whatever results from the Shared Account, so that both B.B.B. and C.C.C. can act independently, without the need for the other co-holder to be present to operate and exercise the rights provided for in the Contract. This is expressly stated in clause 1.4 of the general conditions of the Contract, which literally establishes the following:

1.4. The joint liability is what we will apply unless you tell us otherwise; it means that each of the holders can operate on their own and (...), unless a law indicates otherwise.

Well, one of the rights recognized in the general conditions of the Contract is precisely access to the account and, in particular, the consultation of the balance and transactions, establishing the digital banking platform as a possible channel for exercising that right. Thus, clause 2.1 of the general conditions of the Contract establishes the following:

"You can [...] access the rest of the payment services and consult the balance and transactions [...] through CaixaBank Now."

Considering the solidarity regime established by the parties to the Contract, any of the co-holders of the Shared Account is authorized to independently consult the balance and transactions of that account without requiring the presence of the other co-holder. This is what solidarity consists of. The exercise of rights through third parties.

The individual exercise of a right inherently includes the holder's decision on how they wish to exercise such right, either on their own behalf or through an authorized third party who, acting as a sort of alter ego of the represented party, acts in their stead. In particular, within the scope of the autonomy of their will, the holder of the right may decide to exercise it themselves or through a third party authorized for that purpose, via a power of attorney.

This regime is the same as that established, without conditions, in Article 12 of the LOPD, where the right of access (recognized in Article 15 of the RGPD) can be "exercised directly or through a legal or voluntary representative."

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
22/89

This decision regarding the manner of exercising the right (on one's own behalf or through a third party) falls within the scope of the autonomy of the will of its holder, as the Provincial Court of A Coruña illustratively recalls in its judgment no. 396/2008 of September 22 (AC 2008/1960) in the following terms:

"The foundation of all empowerment and representation lies in the will of the dominus who, under the free autonomy of will stemming from Article 1255 of the Civil Code, grants his representation to another person, the attorney, to act on his behalf in legal transactions, thus generating the so-called hetero-representative efficacy. The will to confer such representation is manifested through a legal transaction: the empowerment. Except for exceptions (power to marry or the general power for litigation, without prejudice to its granting apud acta before the Judicial Secretary), the principle of freedom of form applies in this matter [...]."

In the same vein, the "Guidelines 01/2022 on data subject rights - Right of access. Version 2.0. Adopted on March 28, 2023" issued by the "European Data Protection Board" remind that the form and scope of empowerment is a matter that falls outside the scope of data protection, stating that "national legislations regulating representation (for example, notarial powers), [...] must be taken into account, as the GDPR does not regulate this issue." In the Spanish legal system, as has been stated, the legal transaction of empowerment is not subject to any formalities.

Applying the above to situations of joint ownership, each of the holders can exercise the rights that correspond to them independently of the other co-holder, either by themselves or through a third party representing them. We are faced with a necessary consequence of the legal regime of solidarity: the holder of the right can exercise it as they deem most appropriate.

Therefore, at the moment it was agreed that the Shared Account would be subject to the "solidarity modality" (clause 4 of the specific conditions of the Current Account Contract), both Co-holders consented that each of them could exercise their rights individually, thus consenting that, within the framework of individual exercise and under the autonomy of the will of each co-holder, the rights could be exercised on behalf of the co-holder or by a third party authorized by them.

In this context, and at the moment the co-holders (B.B.B. and C.C.C.) consented that the Current Account would be subject to the solidarity regime, they accepted as a necessary consequence that each of them could independently exercise the rights related to that Account (in particular the right of access to the Account information) in the manner they deemed appropriate: by themselves or by

authorizing a duly qualified third party to exercise that right.

That is precisely what happened in our case, in which B.B.B. (one of the joint holders) could access the data of the Shared Account by herself or by authorizing a third party. Based on the above, B.B.B. authorized her mother (D.D.D.) to access the data of the Shared Account on her behalf. The above is a concrete manifestation of the solidarity regime.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

23/89

that the co-holders agreed with CaixaBank (and that it must be respected by CaixaBank in compliance with the contractual documentation).

(...)

Representation is defined in generic terms as that legal figure by virtue of which a person (representative) is granted the authority to act legally on behalf and in the interest of another person (represented).

Depending on its foundation, representation can be voluntary (if it arises from an act of private autonomy of the representative) or legal (if the representation is imperative as it emanates from a legal provision). In relation to the difference between voluntary representation and legal representation, the ruling of the Civil Chamber of the Supreme Court dated June 22, 1979 (RJ 1979/2908) is particularly illustrative as it establishes the following:

“[...] it should be noted that there is a clear and precise distinction between legal representation and voluntary representation, in that while the former strictly finds its foundation in the Law, and therefore outside the scope of private autonomy, the latter has its cause in the fact that the represented voluntarily grants their representation to the attorney, consequently originating from that private autonomy and finding in it the reason for its effectiveness, ultimately revealing that in the Spanish legal system while voluntary representation is merely a concession of legitimacy of the representative, legal representation emanates from a power of representation that rests immediately on a legal provision [...]”.

Therefore, unlike legal representation, voluntary representation is configured as a manifestation of the private autonomy of the holder of individual rights, who freely decides that a third party shall substitute them in the exercise of such rights under the entrusted terms.

The legal transaction through which the representative relationship is materialized for external purposes is the granting of power of attorney, which is precisely the legal act by virtue of which one person voluntarily grants another a power of representation with the specific scope determined.

It should be noted that the essence of the granting of power of attorney lies in the fact that the representative acts on behalf of the represented, which has effects in the legal sphere of the latter.

Therefore, representation is the institution by which one subject (representative) substitutes another (represented) in the performance of legal activity.

Consistent with the above, and insofar as representation determines the substitution of the represented by the representative in legal transactions, the basis of the representative relationship is trust and fidelity between the representative and the represented, thus configuring it as a personal relationship.

It should be remembered that the legal transaction of granting power of attorney, based on a relationship of trust and fidelity, is subject to the same legal scheme as the mandate and, therefore, is not subject to any formalities, and can even be tacit, as established by Article 1710 of the Civil Code in the following terms:

“The mandate may be express or tacit.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

24/89

The power of attorney can be granted by public or private instrument and even verbally. The acceptance can also be express or implied, the latter being deduced from the acts of the agent. Consequently, the general rule is the freedom of form of the declaration of will of the principal, which has been confirmed by jurisprudence. For example, the Civil Chamber of the Supreme Court in its ruling 133/1994 of February 25 (RJ 1994/1263) recalled the following:

"[...] it is jurisprudential doctrine that the granting of power of attorney is not subject to form 'ad solemnitatem' as established by article 1710, paragraph 2, CC, and it can even arise from an implied declaration of will without opposing the formal requirement indicated in number 5 [...]"

Entering into the analysis of the specific case, it is necessary to highlight that CaixaBank Now allows its users to "appoint other people to use their CaixaBank Now," being able to grant different "levels of access" in favor of the authorized third parties. Thus, the power of attorney granted based on the CaixaBank Now system is legally complete and, of course, binding for CaixaBank.

In particular, and as stated in clause 1.2 of the general conditions of the CaixaBank Now Contract, the following "levels of access" can be granted to authorized third parties, the specific choice of which will determine the scope of the authorization:

"Basic: allows the user to submit documents to carry out various operations, such as direct debits, transfers, etc., that require the signature of the account holder or a user with full powers.

The purpose is for the user to prepare the operations so that you, as the account holder, can consent to them later.

(...)

Therefore, in accordance with the contractual documentation, the holder of the CaixaBank Now contract can authorize third parties to access the services of the digital platform, being able to determine in each case the scope of the authorization granted (choosing in each case the "level of access" granted).

The above demonstrates that CaixaBank allows clients to define the scope of the power of attorney granted on a case-by-case basis. And that power of attorney (with the specific scope in which it has been conferred) must be respected by CaixaBank, so that if it does not allow the authorized third party to access the platform, it would be in breach of the CaixaBank Now Contract.

In this context, the power of attorney system offered by CaixaBank Now is configured as a true digital power of attorney system, allowing the holders of the corresponding contracts to authorize third parties to act on their behalf within the terms in which they have been expressly authorized in the context of access to the digital platform.

This is a very useful instrument: the holder of the current account can access it through CaixaBank Now and, in addition, can empower, for example, tax advisors, managers, administrators, or, in general, any third party.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

25/89

in order to access the accounts of the account holder. The traditional documentary power of attorney is being replaced by virtual power of attorney through CaixaBank Now.

In this case, and by virtue of the CaixaBank Now Contract, B.B.B. authorized her mother (D.D.D.) to access the information of the accounts of which she is the holder, so that, based on her autonomy of will, she authorized her mother to access the digital platform on her own. This is a legally complete power of attorney.

In this regard, it is important to highlight that the scope of the power of attorney granted in favor of B.B.B. included the viewing of the data of the Shared Account. Thus, having been able to limit the object of the authorization to the data of her solely owned accounts, B.B.B. freely and unilaterally decided that the authorization granted in favor of D.D.D. would include the data of the Shared Account, so that CaixaBank had to allow D.D.D. to access the data of the Shared Account.

Exercise of Informational Autonomy

It is very important to highlight that the scope of the authorization was expressly decided by B.B.B.

based on her autonomy of will. Indeed, the CaixaBank Now system allows users to expressly select the viewing options granted to authorized third parties, without CaixaBank imposing a default system of which the user is unaware in any case. The voluntary representation system developed by CaixaBank fully respects the informational autonomy of users. It allows the user to decide with absolute precision whether to empower the representative or authorized person to consult (i.e., view) or to operate (i.e., dispose), and within the scope of consultation, also to delimit the specific products. CaixaBank is the recipient of the scope of the authorization granted by the client. If the client grants authorization to a third party, CaixaBank must comply with the scope of the authorization granted. Therefore, it must allow the authorized access, as well as, in hypothesis, provide the data that the authorized third party requests within the scope of the authorization.

The relevant temporal milestones are outlined below, which show that the scope of the authorization granted in favor of B.B.B. indeed included access to the Shared Account. In particular:

On February 3, 2021, B.B.B. signed the CaixaBank Now Contract and in the process of registering that Contract included D.D.D. as an authorized person, as evidenced by the screenshots provided with the letter dated June 15 from CaixaBank responding to the request from the AEPD (which are reproduced below for ease of reference). In this initial configuration, B.B.B. limited D.D.D.'s access to the accounts of which B.B.B. was the sole holder, excluding the possibility of accessing information related to the Shared Account. This means that D.D.D. did not include visibility of the Shared Account (which ends in 462), as it was expressly excluded by B.B.B., the holder of the CaixaBank Now Contract.

However, the configuration regarding the visibility of the accounts was expressly modified by B.B.B.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

26/89

In particular, on August 4, 2021, the initial display configuration was modified, allowing D.D.D. to view the specific operations of the Shared Account. Specifically, as a result of this configuration change (which was made at the request of B.B.B.), D.D.D. was not only authorized to view the Accounts solely owned by B.B.B., but was also authorized to view Account 462 (which is the Shared Account). Thus, from August 4, 2021, B.B.B. expressly authorized D.D.D. to access information regarding the Shared Account through the digital banking platform, so that the scope of the power of attorney also included access to the Shared Account.

On August 10, 2021, a new modification of the authorization granted to D.D.D. was made, thereby altering its scope and excluding from such authorization the viewing of the cards associated with the CaixaBank Now Contract.

Therefore, as a result of the aforementioned modification, the authorization granted in favor of D.D.D. was limited, excluding from her powers the viewing of transactions made with the cards associated with the various accounts.

On August 11, 2021, B.B.B. again modified the scope of the authorization granted in favor of D.D.D., reinstating the ability to consult the operations of the cards associated with the accounts owned by B.B.B. The above is evidenced by the following screenshot: (...)

In this context, the scope of the power of attorney in favor of D.D.D. as modified on August 11, 2021, includes the consultation of the transactions of the Shared Account, as well as the transactions of the cards associated with those accounts. It should be noted that this was the scope of the power of attorney at the time the claim that led to the initiation Agreement was made. And that was precisely the scope that CaixaBank was required to respect in compliance with the CaixaBank Now Contract.

For all the above reasons, it must be concluded that the scope of the power of attorney in favor of D.D.D. as expressly conferred by B.B.B. includes access to the digital banking platform regarding all accounts of B.B.B. (including the Shared Account), as well as access to information related to the cards associated with those accounts. This is the scope of the power of attorney that B.B.B. freely and unilaterally conferred, and therefore, this is the power of attorney that CaixaBank was required to respect.

As previously mentioned, this has very relevant consequences, both from a civil contractual

perspective and regarding the field of data protection. In particular, if, in relation to the data of a joint account, CaixaBank does not allow access to a third party authorized by one of the co-holders, it will be breaching the contract, as well as the power of attorney granted by that party.

Indeed, in this specific case, if CaixaBank (the counterparty to the Current Account Contract) had prevented the exercise of the rights that belonged jointly to B.B.B. through a third party (D.D.D.), it would have clearly breached the Current Account Contract, as well as the CaixaBank Now Contract. Indeed, B.B.B. had the "right to request" (Article 1,137 of the Civil Code) what results from the Current Account Contract, either personally or through any third party.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

27/89

CaixaBank (articles 1,090, 1,254, and 1,258 of the Civil Code) was required to allow the exercise of the rights of the counterparty that it committed to under the Current Account Contract, regardless of whether the individual exercising those rights was one of the holders of the Shared Account or a third party duly authorized through the CaixaBank Now system.

In this regard, it is important to highlight that the form and scope of the authorization is a matter that falls outside the realm of data protection, as noted in the "Guidelines 01/2022 on data subject rights - Right of access. Version 2.0. Adopted on 28 March 2023" which expressly states the following:

In this sense, national legislations regulating representation (for example, notarial powers), [...] must be taken into account, as the GDPR does not regulate this matter.

In accordance with the principle of accountability, as well as the other principles of data protection, data controllers must be able to demonstrate the existence of the relevant authorization to [...] receive the requested information, unless national legislation differs (for example, if national legislation contains specific rules regarding the reliability of data controllers).

In the Spanish legal system, as previously stated, the legal transaction of authorization is not subject to any formalities, so that the authorization for access to the Shared Account made based on the CaixaBank Now Contract is legally complete and, of course, binding for CaixaBank. At this point, it would be appropriate to pose the following rhetorical question:

If D.D.D. had approached CaixaBank with a notarial power that supported her request for access to the data of B.B.B., should CaixaBank have only provided her with information related to the contracts in which B.B.B. was the sole holder, due to the lack of authorization from the co-holders of the other contracts?

And if we generalize, when an authorized representative (the legal or voluntary representative indicated in Article 12 of the LOPD) requests the exercise of the right of access, must the data controllers deny access to the data of products with co-holders until authorization from the co-holders is provided?

Clearly, the answer, considering current practice and the instructions and resolutions of the AEPD itself, is that the complete right of access must be respected, even if exercised through a representative, unless the AEPD intends to change the criterion through this resolution. It should be noted that it is common for clients to have a variety of products, with a diversity of co-holders (family members, partners, associates, etc.), and this modification of the criterion would significantly affect the ability to exercise the right of access (or others) through a representative.

And having said all of the above, what difference is there between the exercise of the right of access and the consultation of information through an online banking service?

Moreover, D.D.D.'s access to the data of the Shared Account is in accordance with the law as it is consistent with the joint nature of the Shared Account. Indeed, at the moment when C.C.C. consented that the Account

28/89

Shared jointly and severally (as effectively done by signing the Current Account Contract), consented that B.B.B. could exercise its rights as a co-holder individually and, therefore, consented that B.B.B., relying on its private autonomy, could exercise such rights in any manner it deemed appropriate, either

on its own or through an authorized third party. And if the co-holder freely decides to exercise its right through a third party and empowers it for that purpose through the system offered in CaixaBank Now (which is configured as a legally complete system considering the freedom of form of the empowerment transaction), CaixaBank must respect it and, therefore, must allow access to the authorized third party.

In summary, at the moment C.C.C. consented that the account be joint, it consented that B.B.B. access the account information through CaixaBank Now and, therefore, consented that such access could be carried out either by B.B.B. on its own or by a third party authorized by B.B.B. for that purpose (as effectively occurred when empowering D.D.D.).

The above determines that D.D.D., relying on the authorization granted by B.B.B., could, on one hand, access the data of the Shared Account (as such data were included within the scope of the power in its favor) and, on the other hand, request CaixaBank to provide the aforementioned data. If CaixaBank had not allowed access or had refused to provide the requested data, CaixaBank would have incurred a breach of the CaixaBank Now Contract and the Shared Account Contract. As a consequence of the above, the sanctioning procedure must be archived due to lack of typicity. Indeed, the access to the Shared Account by the representative of the co-holder was consented by C.C.C.

As a consequence of the above, the sanctioning procedure must be archived due to lack of typicity. Indeed, the access to the Shared Account by the representative of the co-holder was consented by C.C.C.

The Initiation Agreement improperly considers, said with due respect, that CaixaBank allegedly incurred in certain infractions typified in the GDPR. In particular, the infractions whose attribution the Initiation Agreement seeks to sustain are as follows:

i)
Alleged violation of Article 5.1.f) of the GDPR which establishes the principle of confidentiality of data. In particular, the Initiation Agreement considers that such principle would have been violated in that, according to its understanding (improperly said with due respect), C.C.C. "has not given authorization to the mother of [B.B.B.] to access the data of the card associated with the account of which both claimants are holders." The Initiation Agreement qualifies the alleged violation of the principle of confidentiality as a very serious infraction under Article 72 of the GDPR.

ii)
Alleged infringement of Article 32 of the GDPR which establishes the obligation of data controllers to apply "appropriate technical and organizational measures to ensure a level of security appropriate to the risk."

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
29/89

In particular, the Initiation Agreement considers that CaixaBank would not have adequate security measures in that "the mother of the claimant has continued to have access to the account that the claimants hold in common, despite the fact that the mother of claimant 1 is neither the account holder nor an authorized person to access said account." The Initiation Agreement qualifies the alleged absence of adequate security measures as a serious infringement under Article 73 of the GDPR.

ii)
Alleged infringement of Article 25 of the GDPR for allegedly having violated data protection "from the design of the computer application."

In particular, the Initiation Agreement considers that CaixaBank would have violated data protection "from the design," in that according to the AEPD "through online banking, it should never be allowed for a person to access personal data held in accounts in which they are neither the holder nor an authorized person." The Initiation Agreement qualifies the alleged violation of data protection "from the design" as a serious infringement under Article 73 of the GDPR.

It should be immediately noted that the basis on which the Initiation Agreement attempts to support the commission of the indicated infringements is the alleged lack of consent from C.C.C. for B.B.B. to

access the information of the Shared Account. The above is illustratively reflected in the following paragraph of the Initiation Agreement:

"However, according to the established facts, it seems that the online banking of the accused entity does not require the consent of all holders, but rather it is sufficient to have the consent of one of the holders to allow access to third parties, which violates the data protection of the holders who, being part of a jointly held account, have not given their consent or authorization for third parties to access the transactions of an account in their ownership when such account is shared with other holders." Indeed, based on this alleged lack of consent from C.C.C. (which is denied in any case), the Initiation Agreement constructs the alleged violation of the principle of confidentiality, the alleged absence of adequate measures to protect personal data, and the alleged poor design of the digital banking platform.

However, the approach of the Initiation Agreement ignores an element of considerable importance: The Shared Account is subject to a regime of solidarity (and not of joint ownership). Indeed, as has been stated, the Shared Account is solidary, so that C.C.C. at the time of signing the Shared Account Contract consented to B.B.B. accessing the information of the account through CaixaBank Now and, therefore, consented that such access could be carried out either by B.B.B. on their own or through a third party that B.B.B. authorized for this purpose (in this case D.D.D.). The decision regarding the exercise of rights resides in the realm of the autonomy of the will of its holder, being

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

30/89

It is indifferent whether the right is exercised personally or through a third party by means of a power of attorney.

And if the co-holder freely decides to exercise their right through a third party and grants them power of attorney for that purpose through the system offered in CaixaBank Now (which is configured as a legally complete system in accordance with the freedom of form of the power of attorney transaction), CaixaBank must respect this and, therefore, must allow access to the authorized third party.

Otherwise, CaixaBank would incur a breach of the CaixaBank Now Contract.

It follows from the above that the approach of the Agreement to initiate proceedings would only be correct if the Shared Account were joint. In that case, B.B.B. would need to request C.C.C.'s consent to exercise the right of access to the account. However, this approach does not correspond to the reality of the facts.

In short, D.D.D.'s access was consented to by C.C.C., as the Shared Account was expressly subject to the "joint modality" by the consent of the parties.

Based on the above premise, the infringing types on which the Agreement to initiate proceedings intends to base the sanctioning procedure fall away. Indeed:

- i) The principle of confidentiality was not violated (as C.C.C. consented for B.B.B. to exercise their right of access individually, which includes the granting of power of attorney to a third party for its exercise).
- ii) CaixaBank has adequate security measures in place, and it is not required to establish security measures for authorized third parties by a co-holder to access information about shared accounts. If the account is joint (as it is in this case), any of the co-holders can authorize a third party to exercise their right to access the accounts, considering that such authorization is consented to at the moment the account is submitted to the "joint modality." In fact, to understand otherwise would imply violating the solidarity regime agreed upon by the parties contractually.
- iii) The digital banking platform does not suffer from a design defect, and it is not required to obtain the consent of all co-holders for third parties authorized by one of them to access account information, as long as the account has been submitted to the solidarity regime and, therefore, as long as the co-holders can exercise their rights in the manner they deem appropriate. The above would be equivalent to disregarding the solidarity regime of the Shared Account that was expressly consented to by the co-holders and that must be respected by CaixaBank Now.

Furthermore, in no case could a deficient design of the platform be substantiated considering that, as

has been seen, it allows account holders to configure the access options for third parties. Indeed, and in accordance with clause 1.2 of the general conditions of the Contract.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
31/89

CaixaBank Now, the "access levels" that can be granted to authorized third parties are as follows:

“Basic: allows the user to submit documents to carry out various operations, such as direct debits, transfers, etc., which require the signature of the account holder or a user with full powers.

The purpose is for the user to prepare the operations so that you, as the account holder, can consent to them later.

Consultation: allows the user to consult the contracted services as well as their specific operation.

Consultation and preparation: is the sum of the two previous levels.

All permitted: the user can access all the services offered by CaixaBank Now.

Detailed: the user can have different levels of access, depending on the type of service: current account, investment fund, insurance, etc.”

In this regard, there is no deficient design as the digital banking platform allows account holders to configure third-party access as they deem appropriate, even allowing this access to be customized in “different levels of access, depending on the type of service: current account, investment fund, insurance, etc.”

In short, D.D.D.'s access to the data of the Shared Account in place of B.B.B. and under an authorization expressly granted by her was consented to by C.C.C., who, by consenting to the Shared Account being joint, consented that B.B.B. could exercise her individual rights in the manner she deemed appropriate.

Thus, CaixaBank's action in allowing B.B.B.'s access is atypical, since such access was covered by the contractual documentation signed by the co-holders of the Shared Account. In fact, requiring C.C.C.'s consent would have meant violating the terms of the Shared Account Contract, as it would have meant applying the regime of joint ownership to an account whose co-holders expressly agreed to it being joint.

In this sense, it should be noted that both the Current Account Contract and the power of attorney in favor of D.D.D. are valid legal transactions that were executed in accordance with the Civil Code and from which it follows, precisely, that B.B.B., in independent exercise of her right, could freely authorize D.D.D. to exercise it on her behalf (it would be absurd to require C.C.C.'s express consent for this purpose).

The AEPD cannot seek to alter, beyond its competence, the legal regime of a validly executed contract to derive consequences inappropriate to the civil legal regime of that contract. In this regard, the Guidelines are illustrative as they expressly state that “national legislations regulating representation (for example, notarial powers), [...] must be taken into account, as the GDPR does not regulate this issue.” Indeed, the GDPR does not regulate how they must

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
32/89

the powers of attorney in favor of third parties. This is a civil matter over which the AEPD has no jurisdiction.

For all the above reasons, it is necessary to archive the present procedure due to lack of typicity.

Indeed, as has been seen, access to the Shared Account by the representative of the co-holder was consented to by C.C.C. by agreeing that the Shared Account would be joint, which implies that the infringing types on which the Initiation Agreement intends to base the sanctioning procedure fall away.

(...)

Even if it could be understood that CaixaBank incurred in the indicated infringements of the GDPR

(which it does not), the imputation that the Initiation Agreement would follow would still be inappropriate. This is because, in any case, the subjective element of culpability, which is essential to exercise the sanctioning power, is not present, as expressly stated in Article 28 of Law 40/2015, of October 1, on the Legal Regime of the Public Sector (hereinafter, "Law 40/2015"), which establishes that "only individuals and legal entities [...] who are responsible for the same due to intent or negligence may be sanctioned for acts constituting administrative infringements." This is recalled by the Court of Justice of the European Union in its judgment of December 5, 2023 (Case C-807/2021), which, in relation to the imputation of infringements of data protection regulations, established the following:

"Consequently, it must be declared that Article 83 of the GDPR does not allow for the imposition of an administrative fine for an infringement covered in its paragraphs 4 to 6 without demonstrating that such infringement was committed intentionally or negligently by the data controller and that, therefore, culpability in the commission of the infringement constitutes a requirement for the imposition of the fine.

[...]

In light of the above considerations, it is appropriate to respond to the second preliminary question that Article 83 of the GDPR must be interpreted in the sense that an administrative fine may only be imposed under that provision if it is demonstrated that the data controller, who is both a legal entity and a company, committed, intentionally or negligently, an infringement covered in paragraphs 4 to 6 of that article."

Therefore, in any case, the subjective element must be present to sanction conduct that is considered typical. In this regard, it should be noted that a well-established jurisprudence of the Third Chamber of the Supreme Court has repeatedly ruled on the exemption from liability in the sanctioning field as a consequence of the reasonable application of the rules, in this case, the historical, consolidated, and, until now, unchallenged interpretation of the functioning of joint powers. Among many others, the Judgments of this Honorable Chamber of July 6, 1995 (RJ 5796), January 12, 2002 (RJ 549), and June 30, 2003 (RJ 5754), December 9, 1997 (RJ 485) can be cited. According to the latter:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

33/89

"In order for a legal discrepancy to dispel the culpability of an objectively substantiated regulatory breach, it must be reasonably justified. This, in turn, requires that the contentious points giving rise to that discrepancy be specified, the interpretative alternative that opposes the sanctioning administrative body be supported on those points, and the legal arguments used to defend that differentiated interpretation be presented."

Well, in the case at hand, all conditions are met to apply this doctrine and to conclude that the subjective element in CaixaBank's conduct cannot be appreciated, which would allow for the imposition of the intended sanction, and that, therefore, the attribution of the infringement made in the Initiation Agreement is unfounded.

In particular, CaixaBank's interpretation of the GDPR reasonably leads it to conclude that D.D.D.'s access to the Shared Account is correct, as it is consistent with the solidarity regime to which the aforementioned Account was subjected.

In this sense, the requirement for C.C.C.'s consent for D.D.D. (in place of B.B.B.) to access information loses all meaning when contextualized within the rest of the legal framework and, in particular, with the provisions of the Civil Code, which contemplates solidarity relationships, as well as the figure of the mandate, for which total freedom of form is permitted. To understand otherwise would mean distorting the dynamics of solidarity relationships (which allow for the independent exercise of rights in the manner deemed appropriate), as well as distorting the empowerment, which allows for the independent exercise of rights through a third party (who acts as a sort of alter ego in legal transactions).

So much so that requiring consent in the terms sought by the AEPD would have constituted a breach

of the Current Account Contract, inasmuch as this Contract allows its co-holders to exercise their rights independently (regardless of the manner of exercise) and without the need for the other holder's concurrence.

On the other hand, it should be noted that CaixaBank's actions were diligent in that my client allowed D.D.D. access under the terms expressly authorized by B.B.B. at each moment (thus respecting the solidarity nature of the Shared Account and the authorization granted in favor of D.D.D.). Indeed, the access that D.D.D. had to the accounts of which B.B.B. was the holder (either individually or jointly) conformed to the configuration of views that B.B.B. had freely chosen, with CaixaBank making itself available to modify it according to her preferences.

Furthermore, it cannot be considered that CaixaBank's conduct was culpable, as CaixaBank sought to collaborate with B.B.B. by offering to arrange an in-person meeting so that she could configure the scope of the authorization granted in favor of D.D.D. (and, in particular, to configure the viewing options available to her). However, B.B.B. declined CaixaBank's proposal, as stated in the letter dated June 15 submitted to the AEPD by my client:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
34/89

"The Data Protection Delegate has coordinated, along with the security officers of the Entity, the analysis of the complaint by B.B.B. and, given the impossibility of reproducing the incidents described by the Claimant (1), proposed to hold a meeting with her in which, accompanied by specialists in the Entity's online banking applications, attempts would be made to reproduce the alleged errors and, if it were resolved that there was no technical incident but rather an incorrect configuration of views by the user, she would be assisted in configuring the accesses according to her requirements. This suggestion was adopted and communicated to the Claimant (1) and to the AEPD.

In execution of the DPD's recommendation, CaixaBank attempted to arrange an in-person appointment with the Claimant (1) at her managing office in order to configure, according to her preferences, the operational and viewing powers of her products for the authorized users designated in her Online Banking contract.

The Claimant (1) has declined on several occasions through her manager to maintain this in-person appointment for the review of her viewing and operational preferences of her authorized users, which has made it impossible for CaixaBank to know whether the current configuration of the Claimant (1)'s Online Banking contract is suitable or not to her preferences."

In this context, CaixaBank's conduct cannot be considered culpable since the access that D.D.D. had was in accordance with the viewing configuration that B.B.B. had freely chosen, and CaixaBank tried to collaborate with B.B.B. so that she could configure the scope of the authorization granted, despite her refusal to meet with my represented party. Indeed, CaixaBank maintained a diligent conduct at all times and offered to hold a personal appointment, which never occurred due to B.B.B.'s refusal.

For all the above reasons, even in the hypothetical and denied case of considering that the alleged facts are typical (quod non), it would not be appropriate to sanction CaixaBank for the alleged and denied infringements identified in the Initiation Agreement, since its conduct was motivated by a reasonable interpretation of the applicable regulations and its actions were diligent at all times, so the necessary subjective element for sanctioning is not present."

EIGHTH:

On March 6, 2024, the instructor of the procedure agreed to reproduce for evidentiary purposes the complaint filed by B.B.B. and C.C.C., its documentation, the documents obtained and generated during the admission phase of the complaint, and the report of prior investigative actions that are part of the procedure.

Likewise, the allegations against the initiation agreement of the referenced sanctioning procedure presented by CAIXABANK, S.A., and the accompanying documentation are reproduced for evidentiary purposes.

C/ Jorge Juan, 6

www.aepd.es
28001 – Madrid
sedeagpd.gob.es

35/89

NINTH:

On October 28, 2024, a proposal for resolution was notified, where it is proposed:

That the Director of the Spanish Agency for Data Protection sanctions CAIXABANK, S.A., with NIF A08663619, for the following infringements:

- From Article 5.1. f), GDPR, classified in Article 83.5 a) as very serious for the purposes of prescription in Article 72.1 a) of the LOPDGDD, with a fine of 500,000 euros (five hundred thousand euros).
- From Article 32 of the GDPR, classified in Article 83.4 a) of the GDPR as serious for the purposes of prescription in Article 73 f) of the LOPDGDD, with a fine of 300,000 euros (three hundred thousand euros).
- From Article 25 of the GDPR, classified in Article 83.4 a) of the GDPR and classified as serious for the purposes of prescription in Article 73 d) of the LOPDGDD, with a fine of 3,000,000 euros (three million euros).

The total of the proposed fines amounts to 3,800,000 euros.

That the Director of the Spanish Agency for Data Protection orders CAIXABANK, S.A., with NIF A08663619, to demonstrate, under Article 58.2.d) of the GDPR, within three months from the enforceability of the resolution that is issued, the adoption of the measures taken by the responsible entity to ensure that the processing of personal data it carries out complies with the provisions of the GDPR, specifically regarding the guarantees of confidentiality of the data being processed and the adoption of appropriate technical and organizational security measures based on the risk derived from the processing.

In relation to the infringement of Article 25 of the GDPR, the corrective measures consist of notifying, within nine months from the resolution that concludes this sanctioning procedure becomes enforceable, the adoption of technical and organizational security measures by design and by default, which ensure that the online banking application of the claimed entity protects personal data in general for all clients of the claimed entity.

TENTH:

On November 19, 2024, the claimed entity submitted allegations to the proposal for resolution, literally indicating the following allegations:

(...)

As stated in the written Allegations against the Initiation Agreement, to which we refer in full, the imputation to CaixaBank is senseless, since my represented party's actions were neither typical nor culpable. The above should have necessarily led to the filing of this sanctioning procedure. In particular:

- i) B.B.B. and C.C.C. formalized a current account contract with CaixaBank, based on which they became co-holders of an account.

C/ Jorge Juan, 6

www.aepd.es
28001 – Madrid
sedeagpd.gob.es

36/89

shared account (hereinafter, the “Shared Account” and the “Current Account Contract”). According to the Current Account Contract, being a “joint” current account, each of the holders of the Shared Account could validly exercise their rights in relation to that account independently of the other, without the concurrence of the other holder.

ii)

As derived from the Current Account Contract and the Civil Code, the exercise of the rights arising from the Shared Account can be carried out personally by the holders or through a designated representative for that purpose, who thus substitutes the holder in the exercise of their rights.

iii)

C.C.C., by signing the Current Account Contract, consented to the exercise of all rights arising from it by B.B.B., both personally by her and through any representative she might designate, and to the extent that B.B.B. deemed appropriate.

iv)

B.B.B. empowered her mother, D.D.D., through the “CaixaBank Now” platform to access the current accounts of which she is the holder (including the Shared Account) in execution of the “CaixaBank Now service” contract signed on February 3, 2021 (the “CaixaBank Now Contract”). In particular, the scope of the empowerment (which included the Shared Account) and, therefore, the extent to which the empowered representative (D.D.D.) could access was determined freely and unilaterally by B.B.B., in exercise of her autonomy of will. Indeed, the CaixaBank Now system allows users to expressly select the viewing options for the accounts that clients grant to authorized third parties, without CaixaBank imposing a default (“bulk”) system of which the user is not aware. When D.D.D. was authorized to view the Shared Account, she could view it, and when she was not, she could not. This was evidenced by the screenshots that were attached in response to the information request made by the AEPD (cf. pages 402 and following of the file) and has not been refuted in the Proposal for Resolution.

v)

In the event that CaixaBank opposed access to a shared account by a representative with sufficient empowerment to view the movements of an account, it would be breaching the Current Account Contract (which allows full access to the account, either by each co-holder individually or by a person authorized individually by one or the other), as well as data protection regulations. In particular:

- If CaixaBank does not allow access to the data of a joint account to a third party authorized by one of the co-holders, it will be breaching the current account contract (for violating the expressly agreed solidarity regime), as well as the empowerment granted by that co-holder.
- If, on the other hand, CaixaBank does not provide data related to joint accounts that, hypothetically, a third party, legal or voluntary representative, requests within the framework of a request for a right of access, CaixaBank will be breaching data protection regulations, as it will be preventing the exercise of the right of access provided for in Article 15 of the GDPR, and whose exercise corresponds not only to the holder but also to that third-party representative, as expressly established in Article 12 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter, the “LOPD”).

vi)

In short, D.D.D.'s access to the data of the Shared Account in substitution of B.B.B. and under an authorization expressly granted by her through the CaixaBank Now platform (and whose scope included the viewing of the Shared Account) was consented to by C.C.C., as she consented that the Shared Account be joint and, therefore, consented that B.B.B. could exercise her individual rights in the manner she deemed appropriate (i.e., by herself or through a third party).

In this context, CaixaBank's action in allowing B.B.B.'s access is atypical, as such access was covered by the Current Account Contract. On the other hand, CaixaBank acted diligently and based on a reasonable interpretation of the norm in accordance with the Civil Code. This should have necessarily led to the filing of the sanctioning procedure due to the absence of typicality or, subsidiarily, due to the absence of culpability.

2.

Summary of the grounds for opposition to the Proposal for Resolution

2.1.1 The sanctioning procedure should be archived: CaixaBank did not incur in any typical act.

Absence of typicality.

(...)

With due respect, in this case, there is no “possible collision between the Civil Code and the current regulations on data protection” being raised. The Civil Code regulates the regime of joint and several liability, as well as the regime of empowerment, which are issues not regulated in the GDPR and to which the AEPD must pay attention when analyzing compliance with data protection regulations. Indeed, the legal framework and the requirements for the exercise of the rights of the data subject

through a representative are not harmonized by the GDPR, as recalled in the “Guidelines 01/2022 on data subject rights - Right of access. Version 2.0. Adopted on 28 March 2023” issued by the “European Data Protection Board”,

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
38/89

which is the coordinating organization that brings together national data protection authorities, as well as the European Data Protection Supervisor (hereinafter, the “EDPS Access Rights Guide”). In particular, the Guide establishes that “national legislations regulating representation (for example, powers of attorney), [...] must be taken into account, as the GDPR does not regulate this issue.”

In line with the above, the recent ruling of the Administrative Litigation Chamber of the National Court dated October 3, 2024, is particularly illustrative, in which it was expressly established that the AEPD must take civil regulations into account in order to analyze whether a violation of data protection law has occurred (hereinafter, the “National Court Ruling”).

Indeed, the AEPD cannot ignore the applicable regime regarding the account and the power of attorney granted to D.D.D., but rather, following its previous approach and taking into account the National Court Ruling, it must analyze whether there was a violation of data protection regulations based on the applicable regime concerning the legal relationship between the parties.

This analysis must necessarily lead the AEPD to conclude that indeed D.D.D. could access the Shared Account, considering the joint nature of the Account and the authorization granted in his favor through the CaixaBank Now system. In fact, the AEPD cannot seek to alter, beyond its competence, the legal regime of a validly concluded contract to derive improper consequences from the civil legal regime of that contract.

It should be noted that requiring the co-holder to expressly authorize access to the account by the attorney for the other co-holder, as proposed in the Resolution Proposal, would not only place CaixaBank in a situation of contractual breach and violation of data protection regulations (which expressly provides for the right of access of third-party attorneys), (...).

Thus, as an example, implementing what is proposed in the Resolution Proposal would be tantamount to denying access to joint accounts to those who were authorized for this purpose by a co-holder (even through a power of attorney) until authorization from the other co-holders was provided. This situation could reach the absurdity that the attorney of one of the co-holders could dispose of the funds in the joint account without the express consent of the other co-holder (applying the solidarity regime) and yet could not access the information of that account without the prior express consent of the other co-holder.

On the other hand, the Resolution Proposal suggests that CaixaBank would have acknowledged that the “viewing of personal data [...] by an unauthorized third party corresponds to an incident” in the response provided to the Bank of Spain. With due respect, the fact that the aforementioned document classified the “viewing of personal data” as a technical incident does not imply in any case that CaixaBank was acknowledging any type of responsibility (and even less responsibility for a supposed and denied violation of data protection regulations). In fact, in the response to the request submitted to the AEPD, CaixaBank stated that “the

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
39/89

The operation that the authorized party visualizes is correct” because it responds to the authorization expressly granted in favor of D.D.D. (p. 406 of the administrative file). In any case, the qualification that would be used in the procedure followed before the Bank of Spain when presenting the facts is irrelevant for the purposes of determining CaixaBank's responsibility in the present procedure. CaixaBank can only be held responsible for actions that fall under an infringing type. And in this case,

the element of typicality does not concur, as explained in the Allegations against the Initiation Agreement to which we fully refer.

Furthermore, it should be noted that the approach of the Resolution Proposal is based on an erroneous premise, confusing the figure of the attorney of a bank account with the figure of the authorized party in digital banking. (...) This approach is incorrect insofar as it is not necessary to be the attorney of a specific account (and, therefore, to hold powers that could even include the closure of the account) in order to access information related to that account through the digital banking platform if authorized by the holder of the CaixaBank Now contract, a circumstance that was evidenced in the Allegations against the Initiation Agreement.

It follows from the above that CaixaBank did not incur in any typical act: C.C.C. consented that the representative of the co-holder of the Shared Account could access information of that Account at the moment they consented that the Shared Account would be joint.

Moreover, even in the denied case of considering that CaixaBank incurred in the infringements proposed by the Resolution Proposal, in no case could the infringements related to the alleged absence of adequate measures and the supposed deficiencies in design be attributed due to having prescribed. Indeed, the statute of limitations for both infringements (classified as serious) is two years. The facts that give rise to the attribution of both infringements occurred in 2021, so both infringements expired in 2023. That is to say, before the notification of the Initiation Agreement (dated January 18, 2024).

2.1.1 Furthermore, the sanctioning procedure must be archived, since CaixaBank's actions were not culpable.

Beyond the absence of typicality and the expiration of two of the infringements, it should be noted that in no case could responsibility be attributed to CaixaBank as the element of culpability is also absent. Indeed, as explained in the Allegations against the Initiation Agreement, CaixaBank's actions were consistent with a contextualized interpretation of the data protection regulations in relation to the rest of the legal system and, in particular, with the provisions of the Civil Code applicable to the Current Account Contract, which contemplates joint relationships, as well as the figure of power of attorney, for which total freedom of form is allowed.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
40/89

2.1.2 Without prejudice to the above, in a subsidiary manner and in the hypothetical and denied case that the filing of the procedure is not agreed upon, the proposed sanction should be reduced. (...), in the hypothetical and denied case of considering that CaixaBank engaged in typical and culpable conduct (quod non), the regime of medial concurrence provided for in Article 29.5 of Law 40/2015, of October 1, on the Legal Regime of the Public Sector (hereinafter, "Law 40/2015"), must be applied, which limits the imposition of a single sanction in cases of committing infringements that necessarily derive from others. Furthermore, and for the hypothetical and denied case of not applying the rules of medial concurrence, in no case could two sanctions be applied for the alleged violation of Articles 5 and 32 of the GDPR, as such accusation is based on the same facts, so that in hypothesis only the sanction associated with one of the infringements could be applied, but not to both.

In any case, and without prejudice to the above, the proposed sanctions (totaling 3,800,000 euros) are disproportionate and lack the necessary motivation. In particular, the sanctions do not adhere to the principle of proportionality, considering that access, even if it had been illegitimate (quod non), could in no case have generated real and effective harm to C.C.C.

* * *

In light of the above, the claims of my represented party are that a resolution be issued whereby (i) the filing of this sanctioning file is agreed upon and (ii) subsidiarily, in the event that it is not filed, the sanction is agreed to be reduced in accordance with the principles of non bis in idem and proportionality.

FIRST.- THE SANCTIONING PROCEDURE MUST BE FILED DUE TO LACK OF TYPICALITY. ACCESS TO THE SHARED ACCOUNT BY THE REPRESENTATIVE OF THE CO-OWNER WAS CONSENTED TO BY C.C.C.: THE SHARED ACCOUNT IS SUBJECT TO THE REGIME OF SOLIDARITY. IN ANY CASE, THE INFRINGEMENTS RELATING TO THE ALLEGED LACK OF TECHNICAL MEASURES AND THE ALLEGED VIOLATION OF DATA PROTECTION BY DESIGN HAVE EXPIRED.

1. The sanctioning procedure must be filed due to lack of typicality. The AEPD must observe the applicable regime to the legal relationship between the parties, and cannot ignore it based on the principle of specialty. CaixaBank in no case acknowledged its responsibility. Indeed, as stated in the Allegations against the Initiation Agreement (to which we refer in full), the Shared Account is solidarity-based, so that C.C.C. at the time of signing the Shared Account Contract consented to B.B.B. accessing the account information through CaixaBank Now and, therefore, consented that such access could be performed either by B.B.B. on its own or through a third party authorized by B.B.B. for that purpose (in this case D.D.D.).

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
41/89

(...) it is not necessary to be an attorney for a specific account (and, therefore, to hold powers that could even include the closure of the account) in order to access information related to that account through the digital banking platform if authorized by the holder of the CaixaBank Now contract, a circumstance that was evidenced in the Allegations against the Initiation Agreement.

Furthermore, the only reason for the Resolution Proposal to counter the substantive arguments presented by CaixaBank is that, supposedly, in a case such as the one raised, the regime of solidarity or the power of attorney provided for in civil law does not apply based on the principle of normative specialty, and in this case, data protection regulations should prevail.

With due respect, this assertion is incorrect for the following reasons:

- The principle of specialty requires that the special law be applied preferentially to the general law when a factual situation fits more closely to the fact regulated in the special law. Conversely, the general law will apply in all matters not covered by the special law.
- The regime of solidarity and power of attorney is not provided for in the GDPR and, therefore, its analysis must be subject to civil law (which is the only law regulating these matters). This is evident when considering the Guide to the Right of Access from the EDPB, which expressly states that civil law issues related to power of attorney are not regulated in the GDPR, but rather in national legislation (in our case, the Civil Code). This circumstance, which is of full relevance to resolve the present procedure, has been ignored in the Resolution Proposal. In particular, the aforementioned Guide to the Right of Access establishes the following:

“In this sense, national legislations that regulate representation (for example, notarial powers), [...] must be taken into account, as the GDPR does not regulate this issue.

In accordance with the principle of accountability, as well as the other principles of data protection, data controllers must be able to demonstrate the existence of the relevant authorization to [...] receive the requested information, unless national legislation differs (for example, if national legislation contains specific rules regarding the reliability of data controllers).

- In coherence with the above, the Judgment of the National Court is particularly illustrative, which expressly established that the AEPD must consider the civil law underlying the relationship between the parties to analyze the occurrence of violations in data protection matters.
- In particular, in that case, a third party (the claimant's father) opened an account in the name of his daughter based on a power granted in his favor. The claimant argued that this power did not authorize her father to open an account in her name, since, although the power allowed him to open accounts, his powers were limited to certain assets unrelated to the account that had been opened in her name.

The National Court
C/ Jorge Juan, 6

analyzed the scope of the power conferred in favor of the claimant's father and concluded that in this case, the power did not cover the opening of the account in question, so it considered that Bankia, S.A. (subsequently succeeded by CaixaBank) had incurred a violation of Article 6 of the GDPR.

– In relation to the above, against the argument of the lack of competence of the AEPD, the National Court concluded that the AEPD “does not assess or examine the validity of the contracts signed with the banking entity,” limiting itself to “examining only whether there is lawful consent or not.” And for the purposes of conducting such an examination, the National Court established that the AEPD “has the competence to suppress behaviors that affect the field of data protection, among which are the violations of the principles of consent... And if these principles require that the data of a person processed by a third party is done with their consent, the Agency, solely for the purpose of determining whether or not the violation of the aforementioned principles has occurred, can make an assessment of whether the consent for the processing of the data... has or does not have the coverage of the contracting of such services...”.

– Following this reasoning, the AEPD and subsequently the National Court analyzed the scope of the power granted in favor of the claimant's father and concluded that its terms did not empower him to open an account in his daughter's name. In this case, the AEPD must carry out the same exercise and analyze whether, on the one hand, B.B.B. could exercise her rights individually (considering the joint nature of the Shared Account) and, on the other hand, whether D.D.D. was or was not authorized to access the information of the Shared Account (considering the authorization granted in her favor through the CaixaBank Now system).

– Thus, following its previous reasoning and considering the Judgment of the National Court, the AEPD must analyze whether there was a violation of data protection regulations based on the applicable regime to the legal relationship between the parties.

– This analysis must necessarily lead the AEPD to conclude that indeed D.D.D. could access the Shared Account, considering the joint nature of the Account and the authorization granted in her favor through the CaixaBank Now system.

– Indeed, the AEPD cannot seek to alter, beyond its competence, the legal regime of a validly concluded contract to derive consequences improper to the civil legal regime of that contract.

– It should be noted that the approach followed in the Resolution Proposal is not only legally inappropriate for the reasons stated, (...).

– (...)

– It would be entirely illogical for, on one hand, the attorney to be allowed to manage the funds without the prior authorization of the other co-holders, and on the other hand, to deny access to the viewing of the accounts for not having the prior authorization of the co-holders. The application of this reasoning (which is what the Resolution Proposal defends) would lead to an absurd situation in which the attorney could dispose of all the funds without the express authorization of the other co-holders, while, for example, being unable to know the balance of the account in question.

– Furthermore, applying the reasoning of the Resolution Proposal would not only generate practical problems like the one raised, but would also place CaixaBank in a situation of contractual non-compliance (it would be preventing the co-holders from exercising their rights on behalf of a third party within the framework of a contract of a solidarity nature), as well as non-compliance with data protection regulations. In particular, if the thesis suggested by the Resolution Proposal were applied, CaixaBank would be forced to violate the right of access of the authorized third party in relation to joint accounts, in contravention of Article 12 of the LOPD, which expressly recognizes that “The rights

recognized in Articles 15 to 22 of Regulation (EU) 2016/679 [including the right of access], may be exercised directly or through a legal or voluntary representative.” That article does not provide that, in the event of exercising the right through a representative, additional consent from the co-holders must be obtained.

– In short, invoking the principle of specialty to attempt to displace the application of civil law is incorrect for being legally inappropriate. Moreover, applying the proposed reasoning would imply a change in criteria by the AEPD, which would generate numerous practical problems and negatively impact the exercise of rights by representatives, which would be unjustifiably limited and in contravention of Article 12 of the LOPD.

(...) Without prejudice to the above, and to elaborate further, it should be noted that the Resolution Proposal is inappropriate as it attempts to attribute the violations to CaixaBank based on a supposed “recognition” of its responsibility within the framework of the procedure followed before the Bank of Spain. In particular:

– The fact that in the procedure processed before the Bank of Spain, CaixaBank classified the “viewing of personal data” as a technical incident does not imply in any case that CaixaBank was recognizing any type of responsibility (much less responsibility for a supposed and denied violation of data protection regulations).

– CaixaBank does not dispute that D.D.D. had access to the data of the accounts of which B.B.B. was a holder or co-holder, and that access is not a mistake, but rather the normal functioning of the bank's digital platform since

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

44/89

D.D.D. had access in accordance with the viewing permissions that B.B.B. had expressly granted to her at each moment, as duly stated in the response to the request submitted to the AEPD (p. 406 of the administrative file).

– In any case, the qualification used in the procedure followed before the Bank of Spain when presenting the facts is irrelevant for determining CaixaBank's responsibility in the present procedure. First, because the procedure followed before the Bank of Spain had nothing to do with the imputation of infringements in the field of data protection. And second, because, in any case, the hypothetical and denied acknowledgment referred to in the Proposal for Resolution is irrelevant for the purposes of resolving the present procedure.

– Indeed, CaixaBank can only be held liable for acts that fall under a type of infringement. And in this case, the element of typicality does not exist, as duly stated in the Allegations against the Initiation Agreement to which we refer.

Thus, when D.D.D. was authorized to view the Shared Account, she could view it, and when she was not authorized, she could not. This was evidenced by the screenshots that were submitted in response to the information request made by the AEPD. Indeed, there is not a single video or screenshot that proves that D.D.D. could access the joint account when her daughter had withdrawn that access.

Therefore, the commission of the infringements that are intended to be imputed has not been established. And they have not been established because (as has been evidenced) D.D.D. could only view the Shared Account when she was expressly authorized to do so.

In short, D.D.D.'s access was consented to by C.C.C., as the Shared Account was subject to the "joint modality" by express consent of the parties, so that the co-holders could exercise their rights individually for themselves or through third parties. Based on the above, all the types of infringements that are intended to be imputed fall away:

– The principle of confidentiality was not violated (as C.C.C. consented to B.B.B. exercising her right of access individually, which includes the empowerment of a third party for its exercise).

– CaixaBank has adequate security measures, and it is not required to establish security measures for authorized third parties by a co-holder to access information from shared accounts. If the account is joint (as it is in this case), any of the co-holders can authorize a third party to exercise their right to

access the accounts, considering that such authorization is consented to at the moment the account is submitted to the "joint modality." In fact, understanding otherwise would imply violating the solidarity regime agreed upon by the parties contractually.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
45/89

- The digital banking platform does not suffer from a design defect, as it is not required that the consent of all co-holders be obtained for authorized third parties by one of them to access account information, provided that the account is subject to the solidarity regime and, therefore, that the co-holders can exercise their rights as they deem appropriate. The above would be equivalent to disregarding the solidarity regime of the Shared Account that was expressly consented to by the co-holders and that must be respected by CaixaBank Now.

All of the above must necessarily lead to the filing of the present procedure due to lack of typicity. Indeed, as has been seen, access to the Shared Account by the representative of the co-holder was consented to by C.C.C. by consenting to the Shared Account being solidary, which implies that the infringing types proposed to be imputed by the Proposal for Resolution are extinguished.

2. Alternatively, it is inappropriate to attempt to impute the serious infringements associated with the violation of Articles 32 and 25 of the GDPR, since they have expired.

(...)

These infringements cannot be imputed to CaixaBank as, as stated in the previous section, my represented party has not committed any infringement. However, to further elaborate and for the hypothetical and denied case in which it were considered that CaixaBank incurred such infringements, the Proposal for Resolution would still be incorrect because the infringements provided for in sections f) and d) of Article 73 of the LOPD have expired.

Indeed, in accordance with Article 73 of the LOPD, serious infringements "will expire after two years," with the dies a quo being "the day on which the infringement was committed," as stated in Article 30.2 of Law 40/2015, of October 1, on the Legal Regime of the Public Sector.

In this case, the facts considered typical would have already been committed at the time B.B.B. filed their complaint with the AEPD (i.e., on January 27, 2021, according to the Third Established Fact of the Proposal for Resolution). Therefore, at that moment, the facts considered typical would have already been committed. From the above, it follows that even considering that date as the dies a quo, at the time the Agreement to initiate proceedings was issued, the infringements had already expired since more than two years had passed since the moment the alleged infringement occurred.

The AEPD had two years (i.e., until January 27, 2023) to initiate the sanctioning procedure in order to impute the serious infringements that it improperly seeks to impute now. However, it did not notify the Agreement to initiate proceedings until January 18, 2024 (almost three years after the questioned events occurred).

It follows from the above that, even in the hypothetical and denied case of considering that CaixaBank incurred in the infringements provided for in sections f) and d) of Article 73.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
46/89

of the LOPD, in no case could such infringements be attributed, as they had already prescribed at the time the Agreement to initiate was issued. The above must necessarily lead to the conclusion that, subsidiarily, such infringements should not be attributed and, therefore, that in no case should the sanctions associated with their commission be imposed as proposed in the Resolution Proposal (300,000 euros for the infringement provided for in article 73.f) of the LOPD and 3,000,000 euros for the infringement provided for in article 73.d) of the LOPD).

SECOND.- SUBSIDIARILY, THE SANCTIONING PROCEDURE MUST BE ARCHIVED DUE TO

LACK OF GUILT. CAIXABANK ACTED BASED ON A COHERENT INTERPRETATION OF THE NORM IN ACCORDANCE WITH THE CIVIL CODE.

Even if it could be understood that CaixaBank incurred in the infringements of the GDPR indicated (which it does not), the attribution proposed by the Resolution Proposal would still be inappropriate. This is because, in any case, the subjective element of guilt, which is essential to exercise the sanctioning power, is not present, as expressly stated in article 28 of Law 40/2015, which establishes that “only individuals and legal entities [...] who are responsible for them due to intent or negligence may be sanctioned for acts constituting administrative infringement.” This is recalled in the area of data protection by the Court of Justice of the European Union in its judgment of December 5, 2023 (Case C-807/2021).

Therefore, in any case, the subjective element must be present to sanction a conduct that is considered typical. In this regard, as stated in the Allegations against the Agreement to initiate, it should be noted that a consolidated jurisprudence of the Third Chamber of the Supreme Court has pronounced on numerous occasions regarding the exemption from liability in the sanctioning area as a consequence of the reasonable application of the norms. Among many others, the Judgments of this Honorable Chamber of July 6, 1995 (RJ 5796), January 12, 2002 (RJ 549), and June 30, 2003 (RJ 5754), December 9, 1997 (RJ 485) can be cited. According to the latter:

“For a legal discrepancy to dispel the guilt of an objectively accredited regulatory breach, it is necessary that it is reasonably justified. And this, in turn, requires that the controversial points that raise that discrepancy, the interpretative alternative that is sustained against the sanctioning administrative body on those points, and the legal arguments used to defend that differentiated interpretation are specified.”

In this sense, the requirement of consent from C.C.C. for D.D.D. (in substitution of B.B.B.) to access information loses all meaning when contextualized with the rest of the legal system and, in particular, with the provisions of the Civil Code, which contemplates joint relationships, as well as the figure of the mandate, for which total freedom of form is allowed. Understanding otherwise would imply distorting the dynamics of joint relationships (which allow the

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

47/89

independent exercise of rights in the manner deemed appropriate), as well as to distort the empowerment, which allows the independent exercise of rights through a third party (who acts as a sort of alter ego in legal transactions).

On the other hand, it should be noted that CaixaBank acted diligently insofar as my represented party allowed D.D.D. access under the terms expressly authorized by B.B.B. at all times. Indeed, the access that D.D.D. had to the accounts of which B.B.B. was the holder (either individually or jointly) conformed to the configuration of views that B.B.B. had freely chosen, with CaixaBank making itself available to modify it according to her preferences. The above has not been undermined in the Proposal for Resolution.

Furthermore, it can in no case be considered that CaixaBank's conduct was culpable, as CaixaBank sought to collaborate with B.B.B. from the very first moment when B.B.B. contacted CaixaBank's Customer Service, and from the area of the Data Protection Officer, a call was made to B.B.B., where it was confirmed that there was no incident but rather a configuration that was not to B.B.B.'s liking, and it was referred back to Customer Service to address B.B.B.'s viewing needs. Subsequently, the Data Protection Officer offered to arrange an in-person meeting so that B.B.B. could configure the scope of the authorization granted in favor of D.D.D. (and, in particular, to configure the viewing options available). However, B.B.B. declined CaixaBank's proposal, as stated in the letter dated June 15 submitted to the AEPD.

In this regard, therefore, it can in no case be argued that CaixaBank does not have an adequate procedure for managing claims from interested parties regarding data protection, as, given that there was no infringement in data protection matters, it attended to D.D.D. so that she could change the

viewing options that she herself had configured.

In light of the above, CaixaBank's conduct can in no case be considered culpable, as the access that D.D.D. had conformed to the viewing configuration that B.B.B. had freely chosen, and CaixaBank sought to collaborate with B.B.B. so that she could configure the scope of the authorization granted, despite her refusal to meet with my represented party. Indeed, CaixaBank maintained a diligent conduct at all times and offered to hold a personal appointment, which never occurred due to B.B.B.'s refusal.

THIRD.- WITHOUT PREJUDICE TO THE ABOVE, IN A SUBSIDIARY MANNER AND IN THE HYPOTHETICAL AND DENIED CASE OF NOT ARCHIVING THE PROCEEDINGS, THE APPLICABLE SANCTION MUST BE REDUCED. THE SANCTIONS PROPOSED IN THE PROPOSAL FOR RESOLUTION VIOLATE THE NON BIS IN IDEM PRINCIPLE AND DO NOT ATTEND TO THE PRINCIPLE OF PROPORTIONALITY.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

48/89

1. The sanctions proposed for imposition by the Proposal for Resolution are contrary to the principle of non bis in idem. The rules of medial concurrence must be applied.

32. The infringements that the Proposal for Resolution seeks to impose (i.e., alleged violation of the principle of confidentiality, alleged lack of adequate security measures, and alleged poor design of the digital banking platform) arise from a single fact: the alleged lack of consent from C.C.C. that would supposedly evidence a design error (which is denied in any case). The above is contrary to law as it violates the principle of non bis in idem, which implies the manifest impossibility of imposing two or more administrative sanctions for the same act. In particular:

(i) Violation of the principle of non bis in idem: The Proposal for Resolution seeks to impose three sanctions without applying the rules of medial concurrence. The application of the rules of medial concurrence should lead to the imposition of only the sanction associated with the infringement of Article 5.1.f) of the GDPR. If it is considered that CaixaBank engaged in typical and culpable conduct (which it did not), the regime of medial concurrence provided for in Article 29.5 of Law 40/2015 should be applied, the literal wording of which states the following:

(...) the National Court recognized the appropriateness of estimating the concurrence of infringements based on a medial concurrence among the infringements contemplated in the data protection regulations, when the commission of one necessarily requires the production of the other.

This is precisely what occurs in the present case. Hypothetically, the fact of having incurred in the infringement of Article 25 of the GDPR (design error) would have led to the impossibility of applying adequate measures and, ultimately, violating the principle of confidentiality. Therefore, the alleged commission of one of the infringements has led to the others.

It follows from the above that, applying the ruling of the National Court to the case at hand, only one infringement could be attributed (and one sanction applied), but not three.

Of the three infringements that are sought to be attributed, the most serious is that provided for in Article 5.1.f) of the GDPR (which is classified as very serious). Thus, in accordance with Article 29.5 of Law 40/2015, hypothetically, only that infringement could be attributed, but not the others.

(ii) Furthermore, and for the hypothetical and denied case of not applying the rules of medial concurrence, in no case could two sanctions be applied for the alleged violation of Articles 5 and 32 of the GDPR as such attribution is based on the same facts.

(...)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

49/89

(...) the facts on which the attribution of both infringements is based are the same and basically respond to D.D.D.'s access to the movements of the Shared Account, without the Proposal for Resolution providing the specific elements of violation of each article that, hypothetically, would justify the attribution of two distinct infringements.

In light of the above, and by virtue of the principle of non bis in idem (which prevents the same act from being sanctioned more than once), it is inappropriate to attempt to impose two sanctions for these same facts, so hypothetically only one of the sanctions could be applied, but not both.

2. In any case, and without prejudice to the above, the proposed sanctions are disproportionate and lack the necessary motivation, generating defenselessness for CaixaBank.

(...) It should be noted that the sanctions indicated in the Proposal for Resolution are manifestly contrary to the principle of proportionality to which the AEPD must necessarily adhere, as expressly stated in Article 29.3 of Law 40/2015, the literal wording of which states the following:

“3. In the normative determination of the sanctioning regime, as well as in the imposition of sanctions by Public Administrations, the due suitability and necessity of the sanction to be imposed and its adequacy to the seriousness of the act constituting the infringement must be observed [...]”.

In this regard, the judgment of the Contentious-Administrative Chamber of the National Court of November 18, 2022, is particularly illustrative as it establishes the following:

“According to the repeated jurisprudence of the Supreme Court, such as the Judgment of April 12, 2012 - appeal no. 5.149/2009 -, among others, there must be a due adequacy between the seriousness of the act constituting the infringement and the sanction applied, as provided for in Article 29.3 of Law 40/2015, of October 1.

This principle cannot be exempt from judicial control, as the margin of appreciation granted to the Administration in the imposition of sanctions within the legally established limits must be developed by weighing in all cases the concurrent circumstances, in order to achieve the necessary and due proportion between the imputed facts and the required responsibility, given that every sanction must be determined in congruence with the nature of the infringement committed and according to a criterion of proportionality in relation to the circumstances of the act. Thus, proportionality constitutes a normative principle that is imposed on the Administration and that reduces the scope of its sanctioning powers.”

Well, in this case, it is without any doubt that the sanctions contemplated in the Proposal for Resolution are entirely disproportionate when considering the underlying circumstances of the sanctioning procedure. In particular:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

50/89

- There is only one claim related to viewing permissions, meaning it is not a widespread case but rather a specific incident. The above demonstrates that there is no structural design problem but, at most, a specific situation (which in no case violates data protection regulations). This circumstance must be taken into account when determining the amount of the sanction under Article 83.2.a) of the GDPR.

- Although D.D.D. was able to access information about the Shared Account, they could not dispose of the funds exclusively owned by C.C.C. Therefore, access, even if hypothetically illegitimate, could not have caused any real and effective harm to C.C.C.

- CaixaBank attempted to collaborate with B.B.B. by offering to arrange an in-person meeting so that they could configure the scope of the authorization granted in favor of D.D.D. (and, in particular, to configure the viewing options available). However, B.B.B. declined CaixaBank's proposal, as stated in the letter dated June 15 submitted to the AEPD. This circumstance must be taken into account when determining the amount of the sanction under Article 83.2.c) and f) of the GDPR.

Furthermore, it is inappropriate for the calculation of the sanction to apply Article 83.2.b), which establishes the aggravating factor of "intentionality or negligence in the infringement." Indeed, as the National Court ruling recalls, "Regarding subsection b) intentionality or negligence, this Court has

repeatedly stated that this circumstance should not be applied as an aggravation since it is part of the very nature of the infringement itself, and except in those cases where it is justified and proven that there has been an additional level of intentionality, it is not a circumstance that should be used as an aggravating factor for the conduct." Given these circumstances, in the hypothetical and denied case of considering that an infringement occurred, there would be no evidence of an "additional level of intentionality," which means that under no circumstances could this aggravating factor be considered. On the other hand, it should be noted that the Proposal for Resolution is contrary to the duty of motivation to which all administrations are subject (in accordance with Article 35 of Law 39/2015), since it does not justify at any time the calculation of the considered sanctions. In this regard, the violation of the duty of motivation places my client in a situation of defenselessness, as they are unaware of the specific reasons why the AEPD considers that the first infringement should carry a sanction of 500,000 euros, the second 300,000 euros, and the third 3,000,000 euros. The situation of defenselessness is further aggravated considering the high amount of the sanctions considered in the Proposal for Resolution. (...)

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

51/89

From the actions taken in this procedure and the documentation in the file, the following has been established:

PROVEN FACTS

FIRST:

Claimant 1, B.B.B., is the holder of three bank accounts at CAIXABANK, S.A., specifically as follows:

- ***REFERENCE.1.
- ***REFERENCE.2
- ***REFERENCE.3

In the first of the indicated accounts, Claimant 2 is listed as a co-holder, and in the last two accounts, D.D.D., the mother of Claimant 1, is listed as an authorized person.

SECOND:

The details of the products associated with each account are as follows:

1. ***REFERENCE.1.

In this account, the holders are:

B.B.B. and C.C.C.

The following product is linked to this account:

No. ***REFERENCE.5: Ownership of B.B.B.

Associated with this card contract, C.C.C. is listed as the beneficiary and holder of three cards.

***REFERENCE.7: Ownership of C.C.C.

1. ***REFERENCE.2

In this account, B.B.B. is listed as the holder and D.D.D. and E.E.E. as recognized signatories.

For collection purposes, the following product is linked to this account:

***REFERENCE.6: Ownership of B.B.B. and where D.D.D. is listed as authorized.

2. ***REFERENCE.3

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

52/89

In this account, B.B.B. is listed as the account holder and D.D.D. as the recognized signer.

The following products are linked to this account:

***REFERENCE.8: Ownership of B.B.B. with an associated card.

***REFERENCE.9: Ownership of B.B.B. with an associated card.

***REFERENCE.10: Ownership of B.B.B. with two associated cards.
***REFERENCE.11: Ownership of B.B.B. with an associated card.
***REFERENCE.12: Ownership of B.B.B. with an associated card.
***REFERENCE.13: Ownership of B.B.B. with two guarantors: E.E.E. and D.D.D.
***REFERENCE.14: Ownership of B.B.B.
***REFERENCE.15: Ownership of B.B.B.
***REFERENCE.16: Ownership of B.B.B.
***REFERENCE.17: Ownership of B.B.B.

THIRD:

On 11/01/2021, Claimant 1 informed the Respondent of an incident - reference number ***REFERENCE.18 regarding certain operations in the accounts of which they are the holder.

According to the file, the incident is identified in the following terms:

Your request for multi-signature has been made correctly, but we have not been able to notify all signers. Date 11/01/2021. Time 16:59:39.

On 27/01/2021, Claimant 1 communicated to the Respondent an incident regarding the fact that her mother has access through her CaixaBank electronic banking application (CaixaBank Now) to all financial information not only of herself but also of the account she shares with Claimant 2.

FOURTH:

On 03/02/2021, Claimant 1 signed the CaixaBank Now contract (Contract No. (...) ***REFERENCE.6) related to account ***REFERENCE.2, which allows for electronic operations related to it.

In section 2 of said contract - authorized users - the following is stated: Persons who can access your CaixaBankNow D.D.D., with ID ***NIF.1, User number ***REFERENCE.19 and Operational level.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

53/89

According to page 9 of the aforementioned contract, section 1.2:

Additionally, you may appoint other persons to use your CaixaBankNow:

> Authorized users: you authorize these persons to access your CaixaBankNow at the Basic Access, Consultation, or Consultation and Preparation levels (see the next point), unless you indicate otherwise.

This authorization becomes void when the time period for which you have authorized it ends, or if you inform us that you no longer want the person to be authorized.

> Customized users: you can decide the level of access you grant to these persons, according to the following levels:

> Basic: allows the user to submit documents to carry out various operations, such as direct debits, transfers, etc., which require the signature of the holder or a user with full powers. The purpose is for the user to prepare the operations for you, as the holder, to consent to later.

> Consultation: allows the user to consult the contracted services as well as their specific operations.

> Consultation and preparation: is the sum of the two previous levels.

> All permitted: the user can access all services offered by CaixaBankNow.

> Detailed: the user can have different levels of access, depending on the type of service: current account, investment fund, insurance, etc.

No definition is provided regarding what is to be understood as an authorized user at the operational level.

In the document dated June 16, 2023, from the Respondent, it is stated that,

...no incident has been detected by CaixaBank in the online banking operations of Claimant (1) and the complaints regarding the online banking functionalities of Claimant (1) are due to their own choices in the configuration of the views. (the underlining is ours)

FIFTH:

On 18/01/2021, Claimant 2 signed CaixaBankNOW contract No. (...) ***REFERENCE.7 in which he is

listed as the primary holder, dated 18/01/2021, associated with the account ending in ***REFERENCE.1, and in which no authorized user is listed.

SIXTH:

On 10/02/2021, Claimant 1 again communicated to the Respondent that her mother can also see the products and movements associated with the account ending in ***REFERENCE.1, an account in which she has not been registered as an authorized person.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
54/89

SEVENTH:

On February 11, 2021, Claimant 1 informs Respondent that her mother could see the various products (including mortgage loans, insurance, and bank cards) associated with the accounts held by Claimant 1, including the one in which she is a co-holder along with Claimant 2.

EIGHTH:

On February 17, 2021, Claimant 1 files a complaint with Respondent, outlining all the facts she has been reporting and requesting the termination of what she qualifies as a transfer of data to third parties without authorization. Acknowledgment of receipt of this complaint is recorded on March 23, 2021. In this document, she expresses her wishes regarding her mother's role as an authorized person on the current accounts of which she is the holder and co-holder, indicating that, Therefore, from this moment on, I revoke any "future contract" in the name of B.B.B. that according to my branch I have (I am still awaiting initial documentation) leaving only D.D.D. as an authorized person for the accounts ending in ***REFERENCE.2 and ***REFERENCE.3 as she has always been. (the underlining is ours).

NINTH:

On March 23, 2021, Respondent replies to Claimant 1 indicating that they are processing her complaint, to which they will respond as soon as possible and within a maximum period of one month.

TENTH:

Between February 19 and 21, 2021, Claimant 1 addresses the data protection officer of Respondent regarding the events that occurred.

In her email dated February 21, 2021, Claimant 1 explicitly states that:

1. I attach the complaint sent to my office No. 2409 where I explain everything that has been happening, and I believe it summarizes quite well everything that has been occurring to me. This complaint was signed on 02-16-2021. Please note, as you can read in the complaint, that the first incident where I noticed failures was on 01-11-2021 and from there it has only gotten worse. I attach my ID.
2. The parties involved are C.C.C., D.D.D., and B.B.B.
3. Inability to perform certain operations on all my accounts, due to the mandatory signature of the third party, on accounts where they are nothing. I believe this is explained in the complaint.
4. Transfer of data to a third party, although everything is explained in the complaint, I attach a video where this third party can see banking data that they should not see, and which they have NEVER viewed until the beginning of the year.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

55/89

5. Indicate that my office has been aware of everything from the very first moment, the solutions and explanations (my office transmits them to me, but they are indications given by La Caixa contact center or wherever). All this documentation, plus photos and the failures from the very first moment, is also in her hands. (the underlining is ours)

The only response recorded to these communications is from the data protection officer to the email dated February 9, 2023 (two years after the complaint was filed with this office and dated one day before Respondent responded on February 10, 2023, to the information request made by the AEPD as a result of the filing of the complaint) in which the following is communicated:

We are contacting you regarding your complaint about the operation and visibility of products in your online banking contract (CaixaBank NOW). Given that in the last interactions we have had, we have not been able to configure to your satisfaction the operating and visibility powers of your products for the designated authorized persons, we would like to arrange an appointment with you at your office, which we would attend with the support of the technical departments of the Entity, in order to, following the indications and precisions you provide, restore and reconfigure the authorizations for all your products. We hope that in this way we can test with your intervention all the configurations you indicate, until the operation is to your complete satisfaction.

ELEVENTH:

On June 22, 2021, Claimant 1 filed a complaint with the Bank of Spain - Ref. File: ***REFERENCE.20. TWELFTH:

On ***DATE.2, Claimant 1 receives an email from the lawyers of Respondent with an attached proposal for an agreement, resulting from the complaint filed by Claimant 1 with the Bank of Spain. In it, it is indicated that,

As discussed by phone, we are contacting you as lawyers for CaixaBank, regarding the complaint filed with the Bank of Spain with the reference number mentioned in the subject of the email.

As we have discussed, we wish to convey CaixaBank's willingness to find an amicable solution to the situation raised by you, regarding the possibility of a third party being able to consult the positions of your products, despite not being authorized on them, but only on two sight accounts.

In this regard, and as we have indicated, it seems that there was a technical incident with your and your mother's users that should be resolved with the delivery of new keys with correct access for you and your...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
56/89

mother. In this regard, we will contact the office to initiate the procedures to verify that these keys are issued correctly before citing them for delivery. (the underlining is ours)

Subsequently, on July 21, 2021, the attorneys for the responding party sent an email to claimant 1 indicating that it is a technical issue.

Thus, they state that,

I write to you again to inform you that we are aware that the office staff and you have conducted tests with your new CaixaBankNow user keys and that one of the problems you raised in your complaint has already been resolved. Now it remains for your mother to conduct the corresponding test to verify that with her user she can only access the products of yours in which she is listed as authorized. (the underlining is ours).

After that, on August 10, 2021, the attorneys for the responding party sent an email to claimant 1 indicating that from then on, her mother can only consult the products for which she is authorized.

They point out that,

I write to you again to inform you that the necessary modifications have been made so that your mother can only consult through CaixaBankNow the products for which she is authorized by you.

On the same August 10, claimant 1 responded to the attorneys for the responding party that the issue is still not resolved.

Finally, on August 13, 2021, through the email sent by the attorneys for the responding party to claimant 1, it is shown how the issue, despite the previous assertions of the responding party, was not resolved beforehand.

We apologize for the inconvenience. Unless there is an error, now indeed your mother can only access

to consult the accounts for which she is authorized by you (number ***REFERENCE.2 and ***REFERENCE.3) and without access to card movements.

THIRTEENTH:

In response to the complaint filed with the Bank of Spain, and in order to argue that the claims of the claimant party were satisfied, CaixaBank on July 21, 2021 stated the following: Given these statements, CaixaBank has proceeded to carry out the necessary verifications and has detected that there is a technical issue affecting the digital banking users of the claimant and her mother as authorized.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

57/89

FOURTEENTH:

The Bank of Spain sent claimant 1, on July 26, 2021, a document indicating that this Department of Conduct of Entities has received a letter from CAIXABANK, S.A., which communicates, in relation to the complaint filed on ***DATE.1, that they have proceeded to rectify the situation that was the subject of disagreement, having been notified to her by the entity itself, which is why we consider that her complaint has been satisfied in accordance with the provisions of Article 14 of Order ECC/2502/2012, of November 16, which regulates the procedure for filing complaints with the complaint services of the Bank of Spain, the National Securities Market Commission, and the Directorate General of Insurance and Pension Funds. It is indicated that as of that date, the complaint is archived.

Claimant 1 submits allegations to the Bank of Spain, dated July 26, 2021, stating that she opposes the archiving, expressly indicating that the issue is not resolved.

She states that,

Since January, and through all known channels (the only one who cared was my manager, and even he was not given a response), I have tried to resolve things amicably, but I was NEVER given a solution or even a response. A formal complaint was filed on February 17, to which there was NEVER a solution or response (until the call on July 8) when they are obliged to respond within a MONTH. Let it be clear that the current situation we are in is solely and exclusively due to CaixaBank and their lack of responses from the beginning. Because of this, I feel belittled as a customer, as there has only been a response following the complaint to the BDE.

On the other hand, the current situation of the problem of this complaint remains the same, and obviously, I am not going to stop anything that is not resolved. Furthermore, they have only contacted me when there are more people involved. (the underlining is ours).

FIFTEENTH:

On August 19, 2021, the attorneys for the claimant party sent a letter to the Bank of Spain regarding the complaint filed by claimant 1 with that entity (since after the allegations of claimant 1, the complaint filed by her was not archived).

They indicate that,

ONLY.- CaixaBank has proceeded to make the necessary regularizations of its control marks (replacing "apoderada" with "autorizada"), the source of the administrative error suffered, which automatically updates and corrects the viewing powers that the mother of the claimant has over her products, thanks to which it is currently stated that through the internet digital banking service CaixaBankNow, the mother of the claimant can only make inquiries about the products of

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

58/89

which is authorized, which are currently the current accounts number

***REFERENCE.2 and ***REFERENCE.3.

...In this regard, we justify the regularizations made in this sense, both regarding the accounts and the limitation of card movements: ...this entity requests that the present file be archived, considering the entity as having acquiesced and requesting that the doctrine established by this Department regarding administrative errors be applied, and consequently, declare the non-existence of actions contrary to good banking practices. (the underlining is ours).

SIXTEENTH:

Claimant 2 submits a complaint to the respondent party on October 4, 2021, reporting the same facts as claimant 1.

It indicates that,

Data transfer by Caixa to a third party without authorization.

All cards linked to account ***REFERENCE.1 are viewed by D.D.D.. This has been happening for over 9 months, without you providing a solution to the problem. This lady has nothing to do with my accounts and even less with my cards. My right is being violated by transferring data for months and months.

For all of this, I request that you issue the necessary instructions to correct this immediately. (the underlining is ours).

The respondent party replies on October 27, indicating that it is not possible to admit the facts since it is being processed before the Bank of Spain.

SEVENTEENTH:

By Report of ***DATE.3 from the Bank of Spain, the complaint submitted by claimant 1 is resolved, indicating that,

In this case, between the date (February 17) when the prior complaint was received by the entity and the date when the entity's lawyers contacted the claimant in writing - via email - (July 8), months elapsed. There is no record of a response from the customer service to the complaint other than the acknowledgment of receipt. And although we do not have the document or the data of the authorization that the claimant granted to her mother, in any case, the claimant since February 2021 made her disagreement with the information that her mother had access to, authorized by her, clear to the entity, and reiterated time and again - providing demonstrative videos - that the incident remained unresolved at that date.

. (the underlining is ours).

Furthermore, the report indicates that after the submission of allegations by respondent party 1 regarding the archiving of the complaint submitted to the Bank of Spain,

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

59/89

The banking entity submitted a new written statement of allegations dated August 19, 2021, in which it again requests the archiving of the file due to acquiescence and states that it has made the necessary regularizations of its control marks (replacing “authorized representative” with “authorized”), source of the administrative error suffered, thereby automatically updating and correcting the viewing powers of the claimant's mother.

It states that at that date the claimant's mother could make inquiries, through the CaixaBankNow digital banking service, only about the products for which she is authorized: the current accounts number ...

REFERENCE.2 and ...REFERENCE.3:

The claimant submitted a document on September 2, 2021, to oppose again the acquiescence and archiving of the file, stating that indeed on August 8 and 13 a lawyer informed her indicating that everything was resolved, but that was not the case and her mother could see the credit cards as well as all her mortgage data, life insurance, etc. She claims that, although the documentation provided by CAIXABANK indicates that everything is resolved, as of that date (09/02/2021) it is a lie and provides demonstrative videos. She clarifies that the documentation provided by CAIXABANK consists of screenshots from their computers, and from the beginning her manager verified that this was correct and, although they saw that on the screen, it was not true.

...The entity, in its two written statements of allegations, acknowledges the incident or error and communicates that it has resolved it. As supporting documentation to its allegations, it only provides the email sent to the claimant on July 8, 2021...The claimant, however, in her various writings, the last one on September 2, 2021, indicates that the problem remained unresolved and provides demonstrative videos. Furthermore, she complains of the lack of response from the entity to her complaint, which she first submitted at the bank office on February 17, 2021, and the customer service acknowledged receipt on March 23, 2021.

...At this point, we must point out that the failure to comply with the obligation, by the entities, to attend to and resolve within the deadline the complaints and claims submitted by their customers, which reveals a deficient performance in the functioning of customer service and a neglect towards the user of the financial service, could constitute a breach of transparency regulations (the underlining is ours).

LEGAL GROUNDS

I Competence

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
60/89

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states that: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development, and, insofar as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II Preliminary Issues

It should be noted that, according to Article 4.1 GDPR, "personal data" means any information relating to an identified or identifiable natural person ("the data subject"); an identifiable natural person is one whose identity can be determined, directly or indirectly, particularly by reference to an identifier, such as a name, an identification number, location data, an online identifier, or one or more specific elements of the physical, physiological, genetic, mental, economic, cultural, or social identity of that natural person.

Having established the above, let us recall that the bank transactions of a bank account contain data concerning its holder and, therefore, must be considered personal data in the sense indicated in the

preceding paragraph. In the same vein, credit or debit card transactions are also personal data. For its part, Article 4.2 of the GDPR defines processing as "any operation or set of operations performed on personal data or sets of personal data, whether by automated means or not, such as collection, recording, organization, structuring, storage, adaptation or alteration, retrieval, consultation, use, communication by transmission, dissemination or otherwise making available, alignment, combination, restriction, erasure or destruction."

Finally, it should be noted that, according to paragraph 7 of that provision, the data controller is the natural or legal person, public authority, agency, or other body that, alone or jointly with others, determines the purposes and means of the processing; if the law of the Union or of the Member States determines the purposes and means of the processing, the data controller or the specific criteria for its appointment may be established by the law of the Union or of the Member States.

In light of the above, as indicated in the preceding paragraphs, the complaint is filed due to the access that occurs to the 3 accounts opened in the claimed part, of which in two of them the claimant 1 is the exclusive holder (including all associated products) and in the other is a co-holder with the

61/89

Claimant 2, on behalf of the person (the mother of Claimant 1) who is authorized on only two of the accounts, specifically those ending in ***REFERENCE.2 and ***REFERENCE.3.

We are therefore faced with the processing of personal data of Claimant 1 and Claimant 2 for which the Respondent is responsible.

III Response to the Allegations of the Initiation Agreement

In response to the initiation agreement of this sanctioning procedure, the Respondent entity has presented various statements (indicated in previous sections), asserting that this sanctioning procedure should be archived due to lack of typicity, since D.D.D. (mother of Claimant 1) is authorized by B.B.B. (Claimant 1) to view the information related to account ***REFERENCE.1, which is owned by Claimant 1 and Claimant 2, for which reason it considers that its actions are in accordance with the law, as they comply with the regulations established in the civil code.

In this regard, we must remember that while the Respondent initially acknowledges that this viewing of personal data of Claimant 1 by an unauthorized third party corresponds to an incident—this is stated, for example, in the response provided to the Bank of Spain in the context of the complaint filed by Claimant 1 before that Agency—in the allegations made regarding the agreement that initiates this sanctioning procedure, it claims that this viewing corresponds to an autonomous decision of the Claimant as a result of (i) the joint nature of the account shared with Claimant 2 and (ii) her decision to recognize her mother as authorized on the accounts of which she is the owner—and, therefore, also on the one she shares with Claimant 2.

That is to say, it is only when the procedure is initiated before this Data Protection Agency that, despite having recognized since February 2021 that the facts for which the complaint is made constitute an incident attributable to the Respondent entity itself, and in an argument that seems to evade its responsibility, it claims that the events that occurred stem from a decision of the Claimant herself. It is noteworthy that this incident or error has been acknowledged by the Respondent itself in its response to the Bank of Spain, whose report, dated ***DATE.3, states the following: The entity, in its two written submissions, acknowledges the incident or error and communicates that it has resolved it, and that it is only when a sanctioning procedure is initiated for an alleged violation of personal data protection regulations that it attempts to place the responsibility on the Claimant herself.

Furthermore, the "error" has also been recognized before Claimant 1 on multiple occasions by the Respondent, as evidenced in the proven facts. Thus, for example, in the email dated ***DATE.2 sent to Claimant 1 by the lawyers of the Respondent regarding an attempt at an agreement arising from the complaint filed by Claimant 1 before the Bank of Spain, they confirm...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

62/89

specifically that as we have discussed, we wish to convey to you the intention of CaixaBank to find an amicable solution to the situation raised by you, regarding the possibility of a third party being able to consult the positions of your products, despite not being authorized on them, but only on two sight accounts. In this regard, and as we have indicated to you, it seems that there was a technical incident with the users of you and your mother that should be resolved with the issuance of new keys with correct access for you and your mother. In this sense, we will contact the office in order to initiate the procedures to verify that these keys are issued correctly, before scheduling a meeting to deliver them to you. (the underlining is ours).

At this point, for your interest, let us recall that the Bank of Spain, in the aforementioned report dated ***DATE.3 regarding the figure of the authorized person in a bank account, states the following (the underlining is ours):

Authorized persons are individuals who, with the express consent of the account holders, can generally dispose of the existing balance in the account. They are not authorized to modify the terms of the contract, nor to cancel the account, nor to make withdrawals against the account after the death of the account holder. The status of authorized person is obtained through the express authorization of the account holder or holders, and usually in writing, being a banking practice that at that moment both the signatures of the holders and those of the authorized persons are collected.

In this regard, let us point out that the authorization, as indicated by the Bank of Spain itself, refers to a power of disposition regarding the funds deposited in the bank account. A different matter should be understood regarding the visualization of the movements related to all the products associated with it; a circumstance that has occurred in the case at hand, as reflected in the terms of the claim.

On the other hand, the Bank of Spain states that the status of authorized person is obtained through the express authorization of the account holder or holders. Applied to the case at hand, and considering the account finalized in ***REFERENCE.21 as a shared account between both claimants, the status of authorized person for a third party would require the express authorization of both co-holders. Given that the responding party claims that, once claimant 1 designates her mother as authorized, she acquires that status concerning all accounts held (including the one shared with claimant 2), it can only be understood that this practice would be contrary to what is stated by the Bank of Spain itself.

The responding party, regarding the necessity of consent from claimant 2, has stated in its written allegations the following:

“the requirement for the consent of C.C.C. for D.D.D. (in place of B.B.B.) to access information loses all meaning when contextualized with the rest of the legal system and, in particular, with what is provided in the Civil Code, which contemplates joint obligations, as well as the figure of the mandate, for which total freedom of form is allowed. Understanding what...”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

63/89

Otherwise, it would imply a distortion of the dynamics of solidarity relationships (which allow for the independent exercise of rights in the manner deemed appropriate), as well as a distortion of the empowerment, which allows for the independent exercise of rights through a third party (who acts as a sort of alter ego in legal transactions). So much so that requiring consent in the terms sought by the AEPD would have constituted a breach of the Current Account Contract, insofar as this Contract allows its co-holders to exercise their rights independently (regardless of the manner of exercise) and without the need for the other holder's concurrence.

In this regard, it should be noted that if the responding party were to raise a possible conflict between the Civil Code and the current regulations on personal data protection, it should be indicated that in these cases the principle of specialty applies, according to which the norm with a direct and specific regulation of the matter in question prevails over any other.

Jurisprudential interpretation denies the supplementary nature of the general law in matters directly regulated by the special law. The principle of specialty resolves the problem of the concurrence of laws

or apparent conflicts between them through the preferential and priority application of the special norm. And all this without prejudice to the fact that the responding party itself, in the document sent on August 19, 2021, to the Bank of Spain regarding the claim filed by claimant 1 before that entity, indicates that,

SOLE.- CaixaBank has proceeded to make the necessary adjustments to its control marks (replacement of "empowered" with "authorized"), source of the administrative error suffered... (the underlining is ours).

In this context, the case at hand seeks to determine whether access to the data of the current account, as well as to card No. ***REFERENCE.5, associated with account ***REFERENCE.1, owned by both claimant 1 and claimant 2, constitutes a violation of personal data protection regulations or not.

Since the subject matter pertains to the protection of personal data, in accordance with the principle of specialty, the RGPD and the LOPDGDD apply preferentially due to their specificity in the matter.

Therefore, it is absolutely essential, in addition to what the Bank of Spain indicates in its report dated ***DATE.3, to obtain the consent of both claimants to access the data of card No. ***REFERENCE.5, associated with account ***REFERENCE.1.

This is so because said account is owned by both claimants, not just by claimant 1, which means that both have the right for their personal data to be lawfully processed, which necessarily implies that consent has been granted by, in this case, both holders, all in accordance with Article 6.1 a) of the RGPD.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
64/89

To clarify this point, it should be indicated that the party being claimed is therefore considered responsible for the processing, as it is the one that determines the purposes and means of such activity, by virtue of Article 4.7 of the aforementioned GDPR:

Article 4, paragraph 12 of the GDPR broadly defines "personal data security breaches" (hereinafter referred to as security breaches) as "all breaches of security that lead to the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or unauthorized communication or access to such data."

In this context, it should be noted that allowing access to a third party, in this case, the mother of claimant 1, to the account movements and the products associated with it, in which she is not listed as an authorized person, constitutes a breach of personal data, categorized as a breach of confidentiality. According to the Article 29 Working Party (GT29), a "Breach of confidentiality" occurs when there is an unauthorized or accidental disclosure of personal data, or access to it.

Within the principles of processing provided for in Article 5 of the GDPR, the integrity and confidentiality of personal data are guaranteed in paragraph 1.f) of Article 5 of the GDPR.

On the other hand, Article 32 of the GDPR states the obligation to adopt organizational and security measures adapted to the risk of processing.

Finally, data protection by design and by default, that is, the technical and organizational measures that must be adopted as a minimum in all personal data processing, is regulated in Article 25 of the GDPR.

IV Response to the allegations regarding the proposed resolution

In response to the proposed resolution of this sanctioning procedure, the claimed entity has presented allegations (transcribed in the tenth antecedent), referring, essentially, to the absence of the principle of legality, the absence of culpability, and the lack of proportionality of the amount of the proposed sanction.

Firstly, regarding the absence of the principle of legality, the claimed entity indicates that since the account shared by the claimants is a joint account, the authorization granted by one of the co-holders to a third party allows viewing all the products held by that co-holder, including those related to the joint account, stating that in the case at hand, data protection regulations do not apply, and civil legislation should be referred to, for which they mention a ruling from the National Court, from October 2023,

regarding authorization through a notarized power of attorney related to consent as a basis for legitimacy.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

65/89

Firstly, we must bring to attention the conditions under which the mother of claimant 1 was authorized, which are reflected in the fourth proven fact in the following terms:

On 03/02/2021, claimant 1 signed the CaixaBank Now contract (Contract No. (...) ***REFERENCE.6) related to account ***REFERENCE.2, which allows for electronic operations related to it.

In section 2 of this contract - authorized users - the following is stated:

Persons who can access your CaixaBankNow D.D.D., with ***NIF.1, User number ***REFERENCE.19, and Operational level.

According to page 9 of the aforementioned contract, section 1.2:

Additionally, you can appoint other persons to use your CaixaBankNow:

> Authorized users: you authorize these persons to access your CaixaBankNow at the Basic Access, Consultation, or Consultation and Preparation levels (see the next point), unless you indicate otherwise.

This authorization becomes void when the period for which you have authorized it ends, or if you inform us that you no longer want the person to be authorized.

> Customized users: you can decide the level of access you grant to these persons, according to the following levels:

> Basic: allows the user to submit documents to carry out various operations, such as direct debits, transfers, etc., which require the signature of the holder or a user with full powers. The purpose is for the user to prepare the operations for you, as the holder, to consent to them later.

> Consultation: allows the user to consult the contracted services as well as their specific operations.

> Consultation and preparation: is the sum of the two previous levels.

> All permitted: the user can access all the services offered by CaixaBankNow.

> Detailed: the user can have different levels of access, depending on the type of service: current account, investment fund, insurance, etc.

There is no definition regarding what should be understood as an authorized user at the operational level. (...)

In this regard, we must insist that, contrary to what the claimed entity alleges, the level of authorization of the claimant's mother for which claimant 1 gave consent does not even correspond to the options presented in the contract that the claimed party put forward for claimant 1's signature. Therefore, the consent allegedly granted and on which the claimed party bases its allegations is not valid, as it is not even stated in the document signed by claimant 1 what should be understood by "operational level" authorized.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

66/89

Furthermore, even if that consent had been considered valid, from the moment the claimant expresses, actively and passively, continuously (to the extent that she files complaints with the entity, with her data protection delegate, with the Bank of Spain, and with the AEPD) her opposition to access by the person allegedly authorized by her to the account shared with claimant 2 and the associated products, for the purposes of data protection, and even in the civil sphere, it can be understood that she revoked the consent. Therefore, from that moment on, that processing of personal data would lack legal coverage, and the respondent party should have resolved the issue raised by claimant 1 immediately. On the contrary, the clear will of claimant 1, expressed, as we say, repeatedly, was not

addressed by the respondent party in an attitude that can only be described as highly negligent. As a case in point, let us recall that the communications from claimant 1 dated February 19 and 21, 2021, directed to the Data Protection Delegate of the respondent party, were responded to on February 9, 2023, two years later and only one day before the respondent answered on February 10, 2023, the request for information made by the AEPD, once a complaint had been filed with this Authority. These circumstances would demonstrate an improper attention by the respondent party to the repeated statements by the claimant regarding her opposition to access to her personal information that was occurring.

The respondent party brings up the ruling issued by the National Court, Administrative Litigation Chamber, Section 1, Judgment of October 3, 2024, Rec. 990/2022, in which, as is well indicated in the written allegations, a case is presented regarding the opening of a bank account by a third party without having the power of representation that would enable them to do so. As the respondent correctly points out, the National Court concludes that the contract for the opening of the bank account formalized exceeded the limits of the notarial power granted to the third party. However, the respondent fails to mention that what is precisely determined in this ruling is the need to prove consent for the processing of personal data of an interested party—in this case, the daughter in whose name a bank account is opened based on a notarial power granted to her father, exceeding the limits of the same—and, in the case of the present sanctioning procedure, allowing the visualization of the account shared by claimants 1 and 2 by the mother of the first, without the proper authorization—and that, in the present case, such consent, informed, free, and unequivocal as required by data protection regulations, has not occurred.

It is interesting to bring up part of the argument contained in the aforementioned ruling to reiterate that the respondent did not act with due diligence since, just as in the case at hand

(...) There the banking entity did not act with the diligence that as such an entity is required since it included in the current account a person who was not sufficiently represented in the power used by Carlos Francisco for its opening, and her inclusion was solely due to that generic position of co-owner or member of a community of goods.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

67/89

In the facts that give rise to the present sanctioning procedure and in light of the persistent statements made by the claimants, due diligence was not exercised to put an end to the mother of claimant 1 viewing the shared account and the products associated with it, as the respondent undoubtedly desired.

It is again interesting to recall the literal wording of the judicial ruling brought up by the respondent, which reminds us that the scope of competence of the Data Protection Agency regarding civil matters—such as contracting cases—is limited. In this regard, the National Court recalls that: As the parties acknowledge, this issue has been resolved by the chamber, and we indicate the ruling of May 8, 2014 (appeal no. 1/142/2013): "...we will first analyze the invoked incompetence of the Spanish Data Protection Agency, since in the case at hand, the existence of a contract is raised, which is a civil matter, not a personal data protection issue. This is a matter that [...] has been repeatedly dismissed by the Chamber in the following manner. It is the responsibility of the Spanish Data Protection Agency, according to art. 37.a) of the LOPD, to ensure compliance with data protection legislation and to control its application, as well as to exercise the sanctioning power as provided in Title VII of the aforementioned Law (art. 37.g). Therefore, it has the competence to repress behaviors that affect the field of data protection, among which are the violations of the principles of consent and data quality assessed by the contested administrative resolution and established in arts. 6.1 and 6.3 of the LOPD. And if these principles require that the data of a person processed by a third party be done with their consent and be truthful and accurate, the Spanish Data Protection Agency, solely for the purpose of determining whether or not there has been a violation of the aforementioned principles, can make an assessment on whether the consent for the processing of the affected person's data in

relation to certain services is covered by the contract for those services and on the accuracy and truthfulness of a certain piece of data, such as the existence of a debt reported to a solvency file. In the case at hand, this Data Protection Agency does precisely that; it ensures compliance with data protection regulations and, in this case, considers that the conduct for which the respondent is responsible has not respected the principles contained therein, which has resulted in a violation of the right to data protection of the claimants.

Furthermore, it should be noted that the legal system is not composed of watertight normative sections and that data protection regulations are applicable in a transversal manner, and that the alleged application of civil legislation claimed by the respondent does not outright exclude the application of the GDPR.

On the other hand, the respondent entity, in its allegations to the proposed resolution, qualifies as "irrelevant" the considerations made by the Bank of Spain in the report following the complaint submitted to that Authority by the claimants.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
68/89

In this regard, it should be noted that the Bank of Spain is a supervisory and control authority, recognized in Law 13/1994, of June 1, on the Autonomy of the Bank of Spain, whose Article 7.6 establishes the following among its functions:

"The Bank of Spain must supervise, in accordance with current regulations, the solvency, actions, and compliance with specific regulations of credit institutions."

It is within the framework of its functions that the claimants approached the Bank of Spain on various dates, as stated in the proven facts, and as a result of the procedure carried out by said Supervisory Authority, in its report of December 2021, it makes the statements reflected in the seventeenth proven fact, among which the following stand out:

(...) in any case, the claimant since February 2021 expressed to the entity her disagreement with the information available to or accessed by her mother, authorized by her, and reiterated time and again—providing demonstrative videos—that the issue remained unresolved as of that date. (the emphasis is ours).

(...)

The banking entity submitted a new written statement of allegations dated August 19, 2021, in which it again requests the filing of the case due to compliance and states that it has made the necessary adjustments to its control marks (replacing "apoderada" with "autorizada"), the source of the administrative error suffered, thereby automatically updating and correcting the viewing powers of the claimant's mother.

(...)

...The entity, in its two written statements of allegations, acknowledges the incident or error and communicates that it has resolved it. As documentation attached to its allegations, it only provides the email sent to the claimant on July 8, 2021... The claimant, however, in her various writings, the last one dated September 2, 2021, indicates that the problem remained unresolved and provides demonstrative videos. Furthermore, she complains about the lack of response from the entity to her claim, which she first presented at the bank office on February 17, 2021, and the customer service acknowledged receipt on March 23, 2021.

...At this point, we must point out that the failure of the entities to fulfill the obligation to address and resolve within the stipulated time the complaints and claims presented by their clients, which reveals a deficient performance in the operation of the customer service and a neglect towards the user of the financial service, could constitute a breach of transparency regulations (the emphasis is ours).

These excerpts, in addition to reflecting the insistence and forcefulness with which the claimant expressed her desire for her mother to stop viewing information.

C/ Jorge Juan, 6
www.aepd.es

for which it did not wish to authorize it, also indicates how the responding party acted regarding what was stated—repeatedly and emphatically, we insist—by the claimant, qualifying the situation as an incident or error.

It is only reasonable to question, in light of what is now alleged by the responding party, that if what was raised by claimant 1 was classified within the framework of the investigation conducted by the Bank of Spain as an “incident or error,” it now seeks to question the relevance of such allegations to argue its lack of culpability in the conduct subject to this sanctioning procedure. Thus, this inconsistency regarding the very qualification of the facts (before the banking supervisory authority, an incident or error, and before this AEPD, as an operation derived from the authorization granted by claimant 1) only serves to demonstrate, in our opinion, precisely the responsibility of the responding party in the events that occurred.

And this, of course, without prejudice to the fact that the responding party had consistently considered that the claimed facts were the result of an incident. A position that, as has been evidenced, was only modified when this AEPD initiated sanctioning proceedings for violation of data protection regulations. Furthermore, the AEPD must reiterate that the Bank of Spain, in the report of ***DATE.3 regarding the figure of the authorized person in a bank account, states that the condition of authorized person is obtained by express authorization from the account holder or holders.

Applied to the case at hand, and considering that the account finalized in ***REFERENCE.21 is a shared account between both claimants, the condition of an authorized third party would require the express authorization of both co-holders. Given that the responding party claims that once claimant 1 designates her mother as authorized, she acquires that condition concerning all accounts held (including the one shared with claimant 2), it can only be understood that this practice would be contrary to what was stated by the Bank of Spain, which, let us remember, is the supervisory and control authority of credit institutions and to whose criteria they must adhere.

The responding entity also states in its allegations to the proposed resolution that the violations of Articles 32 and 25 of the GDPR—which correspond to the alleged absence of adequate measures and the alleged deficiencies in design—have expired due to the events occurring in 2021. In response to such assertion, the AEPD must indicate that both violations are not time-barred, since the responding entity has not adopted measures to prevent the commission of both violations, and its non-compliance continues to occur. Thus, the obligation to adopt appropriate technical and organizational security measures to ensure a level of security adequate to the risk arising from the processing of personal data (Art. 32 GDPR) and to establish procedures that take into account privacy by default and from the design arises with the entry into force of the GDPR in May 2018, and its non-compliance remains until measures are adopted in this regard. The events of 2021 only demonstrate the level of compliance with such obligations.

It should be noted that a permanent infringement is considered to exist, as stated by the Supreme Court in its ruling of November 20, 2007 (Rec. 170/2003), regarding “those unlawful behaviors that persist over time and are not exhausted by a single act, determining the maintenance of the unlawful situation at the will of the author, such as the ongoing development of activities without the required authorizations and other similar cases.”

Regarding the allegations concerning the absence of culpability, the entity being claimed against insists on the consent given by the claimant, co-holder of the shared account, which allowed the authorized person (her mother) to view all the products. The AEPD must emphasize again that it is absolutely essential, as indicated by the Bank of Spain in its report dated ***DATE.3, to have the consent of both claimants in order to access the shared account and the products associated with it.

This is the case, since this account is owned by both claimants, not just claimant 1, meaning that both have the right for their personal data to be processed lawfully, which necessarily implies that consent has been granted by both in this case.

In this regard, the AEPD must emphasize the absence of information regarding the conditions of the authorized user of operational level and the deficiencies of consent, as the mere fact that someone consents does not imply that the processing is lawful if such processing is contrary to personal data protection regulations. Furthermore, it must be taken into account that, in the event that initial consent could be considered to have been granted, it has been clearly and insistently revoked as observed from the various statements made by claimant 1 to the entity being claimed against over a period of almost two years.

The entity being claimed against also alleges the existence of non bis in idem and medial concurrence as provided in Article 29.5 of Law 40/2015, of October 1, on the Legal Regime of the Public Sector, which limits the imposition of a single sanction in cases of committing infringements that necessarily derive from others. This is understood in light of the alleged commission of both infringements, Article 5.1 f) and Article 32 of the GDPR, stemming from a single fact.

In response to this argument, we must point out that Article 29 of the LRJSP does not apply to the sanctioning regime imposed by the GDPR, given that the GDPR regulates the principle of proportionality by itself.

The GDPR is a directly applicable European regulation in the Member States, which contains a new, complete, and comprehensive system aimed at ensuring the protection of personal data uniformly across the European Union, which would not be achieved if each supervisory authority applied its national provisions in a manner that could be contrary to that harmonizing principle. And this also applies to the sanctioning regime established in the GDPR, whose provisions must be understood, interpreted, and integrated in a complete and integral manner, thus preserving its ultimate purpose, which is the effective and real guarantee of the fundamental right to the Protection of Personal Data.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

71/89

In fact, a specific example of the non-existence of gaps in the GDPR system is Article 83 of the GDPR, which determines the circumstances that may operate as aggravating or mitigating factors regarding an infringement (Article 83.2 of the GDPR) or that specifies the existing rule concerning a possible concurrent infringement (Article 83.3 of the GDPR), which, unlike Article 29.5 of Law 40/2015, does not consider that only the sanction corresponding to the most serious infringement committed should be imposed, but rather that in the case of infringement of several provisions of the GDPR "the total amount of the fine shall not exceed the amount provided for the most serious infringements." (that is, all infringements are penalized, but the total amount cannot exceed that provided in the GDPR for the most serious infringements).

Article 63.2 of the LOPDGDD enshrines not only the supplementary nature (which would serve to fill gaps, which do not exist, as we have seen) but the subsidiary nature (which is not supplementary) of the general regulations on administrative procedures concerning the rules governing the procedures of the AEPD in matters of data protection.

Article 63.2 of the LOPDGDD states:

2. The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development and, insofar as they do not contradict them, subsidiarily by the general rules on administrative procedures.

The Spanish legislator has thus opted for the principle of subsidiarity, not of supplementarity, of the general rules of administrative procedure over the specific ones of the GDPR and LOPDGDD. This relationship between supplementarity and subsidiarity must be understood in light of the ruling of the Audiencia Nacional of October 23, 2001 (Rec. 390/1999), which recalled that "the recourse to subsidiarity is a formula of normative collaboration for cases of concurrence of norms, that is, for cases

in which two or more of them are applicable to the same factual situation, so that the subsidiary yields in favor of the primary one that, in its case, complements," unlike supplementarity, which aims to fill a gap "in such a way that when a certain situation is not subject to regulation by the initially applicable norm, the supplementary one takes over, always provided that such an operation is not, due to other circumstances, contrary to the legal system."

In the present case, the primary norm would be the GDPR, which expressly regulates in its Article 83.3 the possible existence of more than one infringement of the GDPR in the same processing operations or linked operations (express regulation of a possible concurrent infringement), with the regulation of concurrent infringement provided in Article 29.5 of Law 40/2015 not being applicable precisely due to its subsidiary nature.

Article 83.3 of the GDPR states:

3. If a controller or a processor intentionally or negligently infringes various provisions of this Regulation for the same processing operations or linked operations, the total amount of the administrative fine shall not exceed the amount provided for the most serious infringements.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

72/89

Consequently, it is not possible to apply the subsidiary regulation that contains a different regulation from the main regulation.

To this, we must add that the GDPR does not allow for the development or specification of its provisions by the legislators of the Member States, except for what the European legislator has specifically provided, delimiting it very concretely (for example, the provision of Article 83.7 of the GDPR). The LOPDGDD only develops or specifies some aspects of the GDPR to the extent that it allows and with the scope that it permits.

This is so because the intended purpose of the European legislator is to establish a uniform system throughout the European Union that guarantees the rights and freedoms of natural persons, corrects behaviors contrary to the GDPR, promotes compliance, and enables the free movement of these data. In this sense, we cite, among others, recitals 2 and 13 of the GDPR.

Fines must be effective, proportionate, and dissuasive to achieve the intended purpose of the GDPR. For this system to function with all its guarantees, it is necessary for several elements to be deployed in an integral and complete manner.

The application of rules external to the GDPR regarding the determination of fines in each of the Member States applying their national law, whether due to aggravating or mitigating circumstances not provided for in the GDPR - or in the LOPDGDD in the Spanish case as permitted by the GDPR itself - or due to the application of a medial concurrence with a consequence different from that provided in the GDPR, would undermine the effectiveness of the system, losing its meaning, its teleological purpose, and the will of the legislator, resulting in fines imposed for different infringements ceasing to be effective, proportionate, and dissuasive, and in any case, losing the intention to provide uniformity to the system throughout the European Union. In this way, it would also deprive the interested parties of the effective guarantee of their rights and freedoms, weakening the uniform application of the GDPR. The mechanisms for protecting the rights and freedoms of citizens would be diminished, which would be contrary to the spirit of the GDPR.

The GDPR is endowed with its own principle of proportionality that must be applied in its strict terms. Just as the AEPD is not applying the aggravating and mitigating factors provided in Article 29 of the LRJSP, since the GDPR establishes its own, therefore, there is neither a legal gap nor subsidiary application of the same, nor is there room for the application of the intended regulation of medial concurrence for identical reasons.

Finally, the entity being claimed makes a series of allegations related to the lack of proportionality of the imposed sanction.

Firstly, according to the general conditions for calculating administrative fines provided in Article 83, paragraphs 5 a) - regarding the infringement of Article 5.1 f) of the GDPR - and 4 a) regarding the

infringements of Articles 32 and 25 of the GDPR, the administrative fines contemplated in this case are in the lower range of possible sanctions. Compliance is given,

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
73/89

therefore, in accordance with Article 83.1 of the GDPR: “Each supervisory authority shall ensure that the imposition of administrative fines under this Article for the infringements of this Regulation referred to in paragraphs 4, 5, and 6 are, in each individual case, effective, proportionate, and dissuasive.” On the other hand, the respondent also claims that the proposed sanction is not duly justified because “it should have indicated the amount of the proposed sanction without such aggravating factors, as well as the impact of each of them on it.”

Article 83.2 of the GDPR states that “administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure to those provided for in Article 58, paragraph 2, letters a) to h) and j). In deciding on the imposition of an administrative fine and its amount in each individual case, the following shall be duly taken into account:” (the underlining is ours). This means that the assessment of the sanction as a whole must take into account all and each of the concurrent circumstances in the specific case that are provided for in the aforementioned provision.

In this same vein, the jurisprudence speaks when referring to the principle of proportionality, a principle “fundamental that underlies and presides over the process of scaling sanctions and implies, in legal terms, ‘its adequacy to the seriousness of the act constituting the infringement’ as provided for in Article 29.3 of Law 40/2015, on the Legal Regime of the Public Sector, given that every sanction must be determined in accordance with the nature of the infringement committed and according to a criterion of proportionality in relation to the circumstances of the act.” (Judgments of the Supreme Court of December 3, 2008 (rec. 6602/2004) and April 12, 2012 (rec. 5149/2009) and Judgment of the National Court of May 5, 2021 (rec. 1437/2020), among others).

Thus, the Judgment of the Third Chamber of the Supreme Court, dated May 27, 2003 (rec. 3725/1999), indicates that “Proportionality, specifically belonging to the field of sanctions, constitutes one of the principles governing Administrative Sanctioning Law, and represents a control instrument for the exercise of the sanctioning power by the Administration even within the margins that, in principle, the applicable norm indicates for such exercise. It certainly involves a concept that is difficult to determine a priori, but which tends to adjust the sanction by establishing its specific scaling within the indicated possible margins, to the seriousness of the act constituting the infringement, both in its aspect of unlawfulness and culpability, weighing in its entirety the objective and subjective circumstances that integrate the factual basis for sanctionable conduct (...)”

We can also cite for this purpose the Judgment of the Supreme Court 713/2019, of May 29 (rec. 1857/2018): “We will begin by noting that the proportionality of sanctions implies that they are tempered to the particularized seriousness of the act in conjunction with the circumstances of a subjective nature (which refer to the infringer) and objective nature (which refer to the typical act), noting that in the field of administrative sanctioning law in general and in the area of the securities market in particular, there are no dosimetry criteria similar to those set forth in Article 66 of the Penal Code and that the modifying circumstances differ from those in the criminal field. Let us remember that automatic application, without any nuance, of the...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
74/89

Guiding Principles of Criminal Law in Administrative Sanction Procedures
(S.TS 6-10-2003 Rec.772/1998).

Therefore, the Guidelines 04/2022 of the European Data Protection Committee on the calculation of

administrative fines under the GDPR, in its version of May 12, 2022, submitted for public consultation, indicate that “Regarding the assessment of these elements, increases or decreases in a fine cannot be predetermined through tables or percentages. It is reiterated that the actual quantification of the fine will depend on all the elements collected during the investigation and other considerations related to the previous experiences of the supervisory authority regarding fines.”

In short, since in the present sanctioning procedure the circumstances that were taken into account for the provisional quantification of the sanction as a whole were duly indicated and explained, it is properly justified.

Regarding the fact that only one complaint has been filed—an argument that seems to suggest that the respondent considers the impact of the infringement to be limited—it is pertinent to mention Judgment No. 1792/2024, of the Third Section of the Contentious-Administrative Chamber of the Supreme Court, issued on November 11, 2024, which states the following:

The Spanish Data Protection Agency, in the initiation, processing, and resolution of a sanctioning procedure, may address factual and legal issues connected or related to the facts and arguments contained in the complaint that gives rise to the procedure. And, more specifically, in the course of a sanctioning procedure initiated as a result of one or more complaints regarding personal data protection, when it is noted that the specific infringements reported have a common origin in a document or general instrument that defines the entity's policy on data protection, the AEPD may, and must, make that same document, which contains the privacy policy of the responsible entity, the subject of the sanctioning procedure, in order to examine it, detect its possible shortcomings or deficiencies, and adopt, consequently, the necessary measures within the framework of the sanctioning procedure; (...)

In this regard, the Supreme Court considers that the competencies of the Data Protection Agency extend to examining the actions that, in general, may be carried out by an entity subject to data protection regulations and that are contrary to it, regardless of the number of complaints filed that have allowed the AEPD to become aware of such circumstances.

V Article 5.1.f) of the GDPR

Article 5.1.f) of the GDPR establishes the following:

“Article 5 Principles relating to processing:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

75/89

1.

Personal data shall be:

(...)

f) processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, by means of appropriate technical or organizational measures (‘integrity and confidentiality’).”

In relation to this principle, Recital 39 of the aforementioned GDPR states that:

“[...] Personal data must be processed in a manner that ensures adequate security and confidentiality of the personal data, including to prevent unauthorized access or use of such data and the equipment used for processing.”

The documentation in the file provides clear evidence that the respondent violated Article 5.1 f) of the GDPR, principles relating to processing.

In the present case, the complainants report the access of the mother of complainant 1 to the transactions of the products associated with account ***REFERENCE.1, which is owned by the complainants, including those of card No. ***REFERENCE.5.

However, while the mother of complainant 1 is authorized to access accounts ***REFERENCE.2 and ***REFERENCE.3, of which her daughter, complainant 1, is the sole owner, she does not have the authorization of both owners of account ***REFERENCE.1, and therefore should not have been able

to access the transactions of the products associated with it, including card No. ***REFERENCE.22. Despite this, it has been confirmed by complainant 1 and the entity being complained about that the mother of complainant 1 had access to the transactions of card No. ***REFERENCE.5, associated with account ***REFERENCE.1, that is, she had access to the transactions of an account whose owner is her daughter, complainant 1, but also complainant 2, who has not given authorization to D.D.D., the mother of complainant 1, to access the transactions of card No. ***REFERENCE.5, associated with account ***REFERENCE.1, which is owned by both complainants, not just complainant 1.

We must emphasize that complainant 2 has not given authorization to the mother of complainant 1 either to access the data of the account or to access the data of the card associated with the account of which both complainants are owners.

Article 5.1 f) of the GDPR determines the means through which the maintenance of confidentiality and integrity must be achieved when it specifies “by means of appropriate technical and organizational measures” of all kinds, which are not strictly security measures.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
76/89

In the present case, the respondent has not taken the necessary measures to comply with the wishes of the claimants, who are their clients. Since February 17, 2021, Claimant 1 has expressed their irrevocable and clear intention that their mother should not have access to the account and the products linked to it, of which she is a co-holder along with Claimant 2. Claimant 2 also shows the same unequivocal intention through the claim made on October 4, 2021, directed at the respondent. Access to the personal data of Claimant 1 and Claimant 2 is being continuously made by the mother of Claimant 1 due to the lack of measures by the data controller to prevent unauthorized access by the claimants.

Therefore, it is considered that the known facts constitute an infringement, attributable to the respondent, for violation of Article 5.1.f) of the GDPR.

VI Qualification of the infringement of Article 5.1.f) of the GDPR

If confirmed, the aforementioned infringement of Article 5.1.f) of the GDPR could constitute the commission of the infringements classified in Article 83.5 of the GDPR, which under the heading “General conditions for the imposition of administrative fines” states:

“Violations of the following provisions shall be subject to administrative fines of up to 20,000,000 EUR or, in the case of an enterprise, an amount equivalent to a maximum of 4% of the total annual global turnover of the preceding financial year, opting for the higher amount:

a) the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9; (...)”

In this regard, the LOPDGDD, in its Article 71 “Infringements” establishes that “Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those contrary to this organic law, constitute infringements.”

For the purposes of the statute of limitations, Article 72 “Infringements considered very serious” of the LOPDGDD indicates:

“1. In accordance with what is established in Article 83.5 of Regulation (EU) 2016/679, the following infringements are considered very serious and shall be subject to a three-year statute of limitations:

a) The processing of personal data in violation of the principles and guarantees established in Article 5 of Regulation (EU) 2016/679. (...)”

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

VII Sanction for infringement of Article 5.1 f) of the GDPR

In order to determine the administrative fine to be imposed, the provisions of Articles 83.1 and 83.2 of the GDPR must be observed, which state:

“1. Each supervisory authority shall ensure that the imposition of administrative fines under this article for the infringements of this Regulation indicated in paragraphs 4, 5, and 6 are, in each individual case, effective, proportionate, and dissuasive.

2. Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure to those provided for in Article 58, paragraph 2, letters a) to h) and j). In deciding on the imposition of an administrative fine and its amount in each individual case, the following shall be duly taken into account:

- a) the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question, as well as the number of data subjects affected and the level of damage suffered;
- b) the intentionality or negligence in the infringement;
- c) any measures taken by the controller or processor to mitigate the damage suffered by the data subjects;
- d) the degree of responsibility of the controller or processor, taking into account the technical or organizational measures they have implemented pursuant to Articles 25 and 32;
- e) any previous infringement committed by the controller or processor;
- f) the degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the possible adverse effects of the infringement;
- g) the categories of personal data affected by the infringement;
- h) the manner in which the supervisory authority became aware of the infringement, in particular, whether the controller or processor notified the infringement and, if so, to what extent;
- i) when the measures indicated in Article 58, paragraph 2, have been previously ordered against the controller or processor in relation to the same matter, the compliance with such measures;
- j) adherence to codes of conduct under Article 40 or to approved certification mechanisms under Article 42,
- k) any other aggravating or mitigating factor applicable to the circumstances of the case, such as the financial benefits obtained or the losses avoided, directly or indirectly, through the infringement.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

78/89

For its part, Article 76 "Sanctions and corrective measures" of the LOPDGDD provides:

“1. The sanctions provided for in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679 shall be applied taking into account the criteria for graduation established in paragraph 2 of the aforementioned article.

2. In accordance with the provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account:

- a) The continued nature of the infringement.
- b) The connection of the infringer's activity with the processing of personal data.
- c) The benefits obtained as a result of the commission of the infringement.
- d) The possibility that the conduct of the affected party may have induced the commission of the infringement.
- e) The existence of a merger by absorption after the commission of the infringement, which cannot be attributed to the absorbing entity.
- f) The impact on the rights of minors.
- g) Having, when not mandatory, a data protection officer.
- h) The voluntary submission by the data controller or processor to alternative dispute resolution mechanisms, in cases where there are disputes between them and any interested party.”

In accordance with the transcribed provisions, for the purpose of determining the amount of each

sanction for each infringement, each fine is graduated taking into account the following circumstances: Article 83.2.b) GDPR: “negligence in the processing of data” since, despite being aware of the reported facts when informed by claimant 1 in January 2021, it has not adopted the necessary measures to prevent the infringement from continuing, which is considered to further increase the culpability and unlawfulness of its conduct, as the Bank of Spain Report confirms that the party being claimed does not “demonstrate having diligently corrected the incident or error.” Let us remember that the Bank of Spain Report is dated ***DATE.3 and, in fact, there is no record to date that the incident claimed by the claimants has been resolved.

Article 83.2.e) any previous infringement committed by the data controller or processor; It should also be noted that the entity being claimed has been sanctioned by the AEPD previously through the resolution of 09/09/2022 of PS/00183/2022, for a malfunction of CAIXABANK's online banking, for not properly executing the right of rectification exercised through the online banking of the entity being claimed.

Through the resolutions dated 30/01/2023 and 19/11/2023 corresponding to the sanctioning procedures, PS/00482/2022 and PS/000254/2023, CAIXABANK was sanctioned for data processing without legitimacy, recognizing in the second of them the infringement committed and proceeding with the prompt payment of the imposed sanction in accordance with Article 85 of the LPAC.

CAIXABANK has been sanctioned through the resolution of PS/00388/2022, for Article 32 of the GDPR, due to a security incident involving the provision of a third party's account data (the claimant's daughter) over the phone without having previously verified the identity of the person to whom the data was provided, which is why the entity being claimed was sanctioned for an infringement of Article 32.1 of the GDPR classified under Article 83.4.a) of the GDPR, through a resolution issued on May 22, 2023.

Recently, through the resolution dated 26/10/2023 of PS/00020/2023, CAIXABANK has been sanctioned for several infringements, one of them for the infringement of Article 25 of the GDPR, ordering, furthermore, that pursuant to Article 58.2.d) of the GDPR, within nine months, it must notify the Agency of the adoption of the necessary measures to remedy the identified deficiencies.

Article 76.2.b) LOPDGDD: “The connection of the infringer's activity with the processing of personal data.” The activity of the entity being claimed requires continuous processing of personal data. Likewise, the entity being claimed carries out a high volume of personal data processing for the development of its activity.

The consideration of the circumstances presented allows for the initial assessment of the amount of the fine to be €500,000 for violating the principle of confidentiality of the personal data processed in this specific case.

VIII Article 32 of the GDPR

Article 32 of the GDPR establishes the following regarding the security of processing:

“1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

a) the pseudonymization and encryption of personal data;

b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

80/89

c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;

d) a process of regular verification, assessment, and evaluation of the effectiveness of the technical and organizational measures to ensure the security of processing.

2. When assessing the adequacy of the level of security, particular consideration shall be given to the risks presented by the data processing, in particular as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this article.

4. The controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data may only process such data on instructions from the controller, unless required to do so by Union or Member State law.”

The facts revealed indicate a lack of technical and organizational security measures that, in the specific case at hand, have directly enabled access to personal information of the claimants by an unauthorized third party. In this specific case, therefore, after analyzing the documentation contained in the file and the allegations made by the responding party, the technical and organizational security measures appropriate to the risk of processing, the absence of which has been confirmed, have had a direct impact on the loss of confidentiality of the personal data that occurred, without there being a violation, in this specific case, of Article 32 of the GDPR, as the absence of other independent technical and organizational security measures from the personal data breach has not been established, which must determine the filing of the case.

XI Article 25 of the GDPR

Article 25 of the GDPR, in relation to data protection by design and by default, establishes the following:

“1. Taking into account the state of the art, the cost of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity posed by the processing to the rights and freedoms of natural persons, the controller shall implement, both at the time of determining the means of processing and at the time of the processing itself, appropriate technical and organizational measures, such as pseudonymization, designed

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

81/89

to effectively apply the principles of data protection, such as data minimization, and to integrate the necessary safeguards in processing, in order to comply with the requirements of this Regulation and protect the rights of the data subjects.

2. The data controller shall implement appropriate technical and organizational measures to ensure that, by default, only personal data that is necessary for each specific purpose of the processing is processed. This obligation shall apply to the amount of personal data collected, the extent of its processing, its retention period, and its accessibility. Such measures shall ensure, in particular, that, by default, personal data is not accessible, without the intervention of the individual, to an indeterminate number of natural persons.

3. An approved certification mechanism under Article 42 may be used as an element to demonstrate compliance with the obligations set out in paragraphs 1 and 2 of this Article.”

The entity being complained about states to the AEPD in response to the request made by it, that, in this specific case, Claimant 1 has configured her account in such a way that her mother can see the data in all accounts. However, beyond these statements and as indicated in the previous investigation proceedings of this AEPD, the entity has not managed to prove that this is the case.

Beyond the above assertion, it is evident that there has been a violation of the proper protection of personal data from the design of the financial entity's software application, since, as they claim, it could allow their clients, any client, to grant access to their accounts to third parties in the online application without the express authorization of all account holders in cases of joint accounts.

It should be noted, in relation to the aforementioned infringements, that for this reason, the mother of Claimant 1 should not see the personal data of the joint account of the claimants as she is neither a

holder nor authorized by any of them.

Specifically, this is evident in the specific case, which serves as an example regarding privacy by design, that in the response of the entity being complained about it is stated: "On August 4, 2021, at the request of Claimant (1), a modification was made regarding the options described in the previous point concerning the visualization and management established in the registration for D.D.D., changing the visibility level from 'All allowed' to 'Customized', and expanding the visibility over the accounts of the Claimant. Specifically, visibility was allowed for the accounts ending in: ***REFERENCE.2, ***REFERENCE.4, ***REFERENCE.3, ***REFERENCE.1."

These circumstances exemplify a poor design established by the entity being complained about in its application for all clients, as through online banking, it should never be possible to allow a person to access personal data contained in accounts in which they are neither a holder nor an authorized person.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
82/89

Furthermore, the financial entity continues by stating: "and the claims regarding the functionalities of the online banking of the Claimant (1) are due to their own choices in the configuration of the views." Therefore, the AEPD considers that even if a customer had eventually modified their configuration, a proper application of online banking should not allow, under any circumstances, anyone to view an account of which they are neither the holder nor authorized.

In addition to the aforementioned, it is considered that there is also sufficient evidence of a defect in the design of the software application that provides access to the online banking of the entity being claimed against.

This is the case, as it has been established that the software application providing access to online banking does not contemplate the possibility of accounts with more than one holder, because it seems that it does not take into account the requirement to obtain the consent of all holders in accounts that have more than one holder.

It is reasonable to consider the necessity of obtaining the consent of all holders, and not just one of them, so that authorized third parties can access the transactions of those accounts that have multiple holders.

However, according to the established facts, it appears that the online banking of the entity being claimed against does not require the consent—expressed through explicit authorization—of all holders, but is sufficient with the consent of one of the holders to allow access to third parties, which violates the data protection of the holders who, being part of a jointly held account, have not given their consent or authorization.

For this reason, it is considered that the online banking application of the entity being claimed against has not established a special and adequate procedure for those accounts with more than one holder, as it does not require the necessity of obtaining the consent of all holders of the accounts prior to granting, where applicable, the possibility of access to the transactions of such accounts by non-holder but authorized third parties.

Furthermore, there is a lack of a procedure for managing claims from interested parties regarding data protection.

This is evidenced in the specific case by the absolute lack of response from the data protection officer, who responds to Claimant 1 two years after they reported the alleged facts (from February 2021 to February 2023), and just the day before the entity being claimed against provided the AEPD with the requested information in response to the complaint filed.

Similarly, from February 17, 2021, to July 8, 2021, there was neither a response nor any solution to the complaint filed by Claimant 1.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid

Nor was there a substantive response to the complaint from Claimant 2 on the pretext that the complaint filed by Claimant 1 was being resolved at the Bank of Spain.

It should also be noted that until the claimants approached the AEPD, they were repeatedly informed by the entity being claimed against, as well as by the Bank of Spain, that it was a technical incident. It is utterly surprising that before the AEPD it is stated that there has been no incident or error, but rather it has been an action derived from the claimant's decision to grant a certain profile, holding them responsible for the situation that occurred.

If there had been a procedure, the issue suffered by the claimants would have been adequately addressed and resolved.

According to the available evidence, it is considered that there would be a defect in the design of the software application that provides access to the online banking of the entity being claimed against, and therefore, the known facts constitute an infringement, attributable to the entity being claimed against, for violation of Article 25 of the GDPR.

XII Qualification of the infringement of Article 25 of the GDPR

If confirmed, the aforementioned infringement of Article 25 of the GDPR could constitute the commission of the infringements classified in Article 83.4 of the GDPR, which under the heading "General conditions for the imposition of administrative fines" states:

"Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to a maximum of 2% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)"

In this regard, the LOPDGDD, in its Article 71 "Infringements" establishes that "Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements."

For the purposes of the limitation period, Article 73 "Infringements considered serious" of the LOPDGDD indicates:

"Based on what is established in Article 83.4 of Regulation (EU) 2016/679, the following are considered serious and shall prescribe after two years: infringements that constitute a substantial violation of the articles mentioned therein and, in particular, the following:

d) The failure to adopt those technical and organizational measures that are appropriate to effectively guarantee the principles of data protection.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

from the design, as well as the non-integration of the necessary guarantees in the processing, in the terms required by Article 25 of Regulation (EU) 2016/679."

XIII Sanction of Article 25 of the GDPR

In order to determine the administrative fine to be imposed, the provisions of Articles 83.1 and 83.2 of the GDPR must be observed, which state:

"1. Each supervisory authority shall ensure that the imposition of administrative fines under this article for the infringements of this Regulation indicated in paragraphs 4, 5, and 6 are, in each individual case, effective, proportionate, and dissuasive.

2. Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure to those provided for in Article 58, paragraph 2, letters a) to h) and j). In deciding the imposition of an administrative fine and its amount in each individual case, the following shall be duly taken into account:

a) the nature, gravity, and duration of the infringement, taking into account the nature, scope, or

purpose of the processing operation in question, as well as the number of data subjects affected and the level of damage suffered;

b) the intentionality or negligence in the infringement;

c) any measures taken by the controller or processor to mitigate the damage suffered by the data subjects;

d) the degree of responsibility of the controller or processor, taking into account the technical or organizational measures they have implemented pursuant to Articles 25 and 32;

e) any previous infringement committed by the controller or processor;

f) the degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the possible adverse effects of the infringement;

g) the categories of personal data affected by the infringement;

h) the manner in which the supervisory authority became aware of the infringement, in particular whether the controller or processor notified the infringement and, if so, to what extent;

i) when the measures indicated in Article 58, paragraph 2, have been previously ordered against the controller or processor in relation to the same matter, the compliance with such measures;

j) adherence to codes of conduct pursuant to Article 40 or to certification mechanisms approved under Article 42,

k) any other aggravating or mitigating factor applicable to the circumstances of the case, such as the financial benefits obtained or the losses avoided, directly or indirectly, through the infringement.”

For its part, Article 76 “Sanctions and corrective measures” of the LOPDGDD states:

“1. The sanctions provided for in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679 shall be applied taking into account the criteria for graduation established in paragraph 2 of the aforementioned article.

2. In accordance with the provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account:

a) The continued nature of the infringement.

b) The connection of the infringer's activity with the processing of personal data.

c) The benefits obtained as a result of the commission of the infringement.

d) The possibility that the conduct of the affected party may have induced the commission of the infringement.

e) The existence of a merger by absorption after the commission of the infringement, which cannot be attributed to the absorbing entity.

f) The impact on the rights of minors.

g) Having, when not mandatory, a data protection officer.

h) The voluntary submission by the controller or processor to alternative dispute resolution mechanisms, in cases where there are disputes between them and any data subject.”

According to the transcribed provisions, for the purpose of determining the amount of each sanction for each infringement, each fine is graduated taking into account the following circumstances:

Article 83.2.b) GDPR: “negligence in the processing of data” as the data controller is engaged in banking activity, having to process personal data of its clients and third parties for such purposes. The failure to request the necessary data protection consents from its clients, when these are required, by one who is a specialized agent in financial and banking activities constitutes a serious lack of diligence. Thus, in the application designed by the responding party, it seems that the online banking of the entity does not require the consent—expressly manifested through explicit authorization—of all holders, but is sufficient for it.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

86/89

with the consent of one of the holders to allow access to third parties, which violates the data protection of the holders who, being part of a joint account, have not given their consent or authorization.

Article 83.2 e) any previous infringement committed by the data controller or the data processor; It should also be noted that the entity being claimed has been sanctioned by the AEPD previously through the resolution of 09/09/2022 of PS/00183/2022, for a malfunction of CAIXABANK's online banking, for not adequately carrying out the right of rectification exercised through the online banking of the claimed entity.

Through the resolutions dated 30/01/2023 and 19/11/2023 corresponding to the sanctioning procedures, PS/00482/2022 and PS/000254/2023, CAIXABANK was sanctioned for data processing without legitimacy, recognizing in the second of them the infringement committed and proceeding to the prompt payment of the imposed sanction in accordance with Article 85 of the LPAC.

CAIXABANK has been sanctioned by the resolution of PS/00388/2022, for Article 32 of the GDPR, due to a security incident involving the provision of a third party's account data (the claimant's daughter) over the phone without having previously verified the identity of the person to whom the data was provided, for which reason the claimed entity was sanctioned for an infringement of Article 32.1 of the GDPR classified under Article 83.4.a) of the GDPR, by resolution issued on May 22, 2023.

Recently, by resolution dated 26/10/2023 of PS/00020/2023, CAIXABANK has been sanctioned for several infringements, one of which is for the infringement of Article 25 of the GDPR, ordering, furthermore, that pursuant to Article 58.2.d) of the GDPR, within nine months, it notify the Agency of the adoption of the necessary measures to remedy the identified deficiencies.

Article 76.2 b) LOPDGDD: "The link between the infringer's activity and the processing of personal data." The activity of the claimed entity requires continuous processing of personal data. Likewise, the claimed entity carries out a high volume of personal data processing for the development of its activity. The consideration of the circumstances presented allows for an initial assessment of the amount of the fine to be €3,000,000 for the infringement of Article 25 of the aforementioned GDPR, for violating personal data protection by design in general, for all customers of the claimed entity who are users of the online banking of said entity.

XIV Responsibility

The Law 40/2015, of October 1, on the Legal Regime of the Public Sector, establishes in Chapter III relating to the "Principles of the Sanctioning Power," in Article 28 under the heading "Responsibility," the following:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

87/89

"1. Only individuals and legal entities may be sanctioned for acts constituting administrative infringement, as well as, when a law recognizes their capacity to act, groups of affected individuals, unions and entities without legal personality, and independent or autonomous assets, that are responsible for them by way of intent or negligence."

The lack of diligence of the claimed party is clear, as has been duly demonstrated throughout the procedure.

XV Measures

As a consequence of each of the indicated infringements, it could be agreed to impose on the responsible party the adoption of appropriate measures to adjust its actions to the regulations mentioned in this act, in accordance with the provisions of the aforementioned Article 58.2 d) of the GDPR, according to which each supervisory authority may "order the controller or processor to ensure that the processing operations comply with the provisions of this Regulation, where appropriate, in a specified manner and within a specified time frame...". The imposition of this measure is compatible with the sanction consisting of an administrative fine, as provided in Article 83.2 of the GDPR.

Specifically in this case, the measures consist of informing, within three months from the enforceability of the resolution that is issued, of the measures adopted by the responsible entity to ensure that the processing of personal data it carries out complies with the provisions of the GDPR, specifically regarding the guarantees of confidentiality of the data being processed and the adoption of appropriate

technical and organizational measures of all kinds.

In relation to the infringement of Article 25 of the GDPR, the measures consist of notifying, within nine months from when the resolution that concludes this sanctioning procedure becomes enforceable, the adoption of technical and organizational security measures by design and by default, that ensure that the online banking application of the claimed entity protects personal data generally for all customers of the claimed entity.

It is warned that failure to comply with the requirements of this agency may be considered an administrative infringement in accordance with the provisions of the GDPR, classified as an infringement in its Articles 83.5 and 83.6, which may motivate such conduct to open a further administrative sanctioning procedure.

Therefore, in accordance with the applicable legislation and evaluated the criteria for the graduation of the sanctions whose existence has been accredited, the Director of the Spanish Agency for Data Protection,

RESOLVES

FIRST: TO IMPOSE on CAIXABANK, S.A., with NIF A08663619, for the following infringements:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

88/89

- From Article 5.1. f), GDPR, classified in Article 83.5 a) as very serious for the purposes of prescription in Article 72.1 a) of the LOPDGDD, a fine of 500,000 euros (five hundred thousand euros)

- From Article 25 of the GDPR, classified in Article 83.4 a) of the GDPR and qualified as serious for the purposes of prescription in Article 73 d) of the LOPDGDD, a fine of 3,000,000 (three million euros).

The total sum of the proposed fines amounts to 3,500,000 euros.

SECOND: TO FILE the infringement of Article 32 of the GDPR.

THIRD: TO ORDER CAIXABANK, S.A., with NIF A08663619, that pursuant to Article 58.2.d) of the GDPR, within three months from the enforceability of the resolution that is issued, to adopt the measures taken by the responsible entity to ensure that the processing of personal data it carries out complies with the provisions of the GDPR, specifically regarding the guarantees of confidentiality of the data being processed and the adoption of appropriate technical and organizational measures of all kinds.

In relation to the infringement of Article 25 of the GDPR, the measures consist of notifying, within nine months from when the resolution that concludes this sanctioning procedure becomes enforceable, the adoption of technical and organizational security measures by design and by default, which ensure that the online banking application of the entity being claimed protects personal data in general for all clients of the entity being claimed.

FOURTH: This resolution will be enforceable once the period for filing the optional appeal for reconsideration (one month from the day following the notification of this resolution) has expired without the interested party having exercised this right.

The sanctioned party is warned that they must fulfill the imposed sanction once this resolution becomes enforceable, in accordance with the provisions of Article 98.1.b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter LPACAP), within the voluntary payment period established in Article 68 of the General Collection Regulation, approved by Royal Decree 939/2005, of July 29, in relation to Article 62 of Law 58/2003, of December 17, by making the payment, indicating the NIF of the sanctioned party and the procedure number that appears in the heading of this document, into the restricted account No. IBAN:

ES00-0000-0000-0000-0000-0000 (BIC/SWIFT Code: CAIXESBBXXX), opened in the name of the Spanish Agency for Data Protection at the banking entity CAIXABANK, S.A. Otherwise, collection will proceed in the executive period.

Upon receipt of the notification and once enforceable, if the date of enforceability falls between the 1st and the 15th of each month, inclusive, the deadline for voluntary payment will be until the 20th of the

following month or the next business day thereafter, and if it falls between the 16th and the last day of each month, inclusive, the payment deadline will be until the 5th of the second month following or the next business day thereafter.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

89/89

In accordance with the provisions of Article 76.4 of the LOPDGDD and given that the amount of the imposed sanction exceeds one million euros, the information identifying the offender, the infringement committed, and the amount of the sanction will be published in the Official State Gazette.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of the LPACAP, the interested parties may optionally file an appeal for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and Section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law. Finally, it is noted that in accordance with the provisions of Article 90.3 a) of the LPACAP, the final resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the contentious-administrative appeal. If the Agency is not aware of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, the provisional suspension will be considered terminated.

938-16012024

Mar España Martí
Director of the Spanish Agency for Data Protection
C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es